

DOMAIN 5

PROTECTION OF INFORMATION ASSETS

1

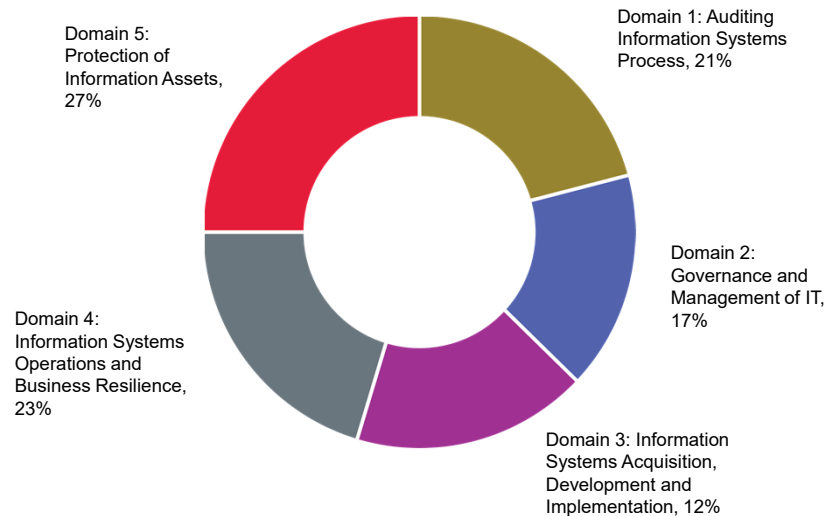
DOMAIN 5

Domain 5 focuses the key components that ensure confidentiality, integrity and availability (CIA) of information assets. The design, implementation and monitoring of logical and physical access controls are explained. Network infrastructure security, environmental controls, and processes and procedures used to classify, enter, store, retrieve, transport and dispose of confidential information assets are covered. The methods and procedures followed by organizations are described, focusing on the auditor's role in evaluating these procedures for suitability and effectiveness.



2

ON THE CISA EXAM



ISACA

3

DOMAIN 5 OBJECTIVES

Upon completion of this domain an IS auditor should be able to:

- Conduct audit in accordance with IS audit standards and a risk-based IS audit strategy.
- Evaluate problem and incident management policies and practices.
- Evaluate the organization's information security and privacy policies and practices.
- Evaluate physical and environmental controls to determine whether information assets are adequately safeguarded.
- Evaluate logical security controls to verify the confidentiality, integrity, and availability of information.
- Evaluate data classification practices for alignment with the organization's policies and applicable external requirements.
- Evaluate policies and practices related to asset lifecycle management.
- Evaluate the information security program to determine its effectiveness and alignment with the organization's strategies and objectives.
- Perform technical security testing to identify potential threats and vulnerabilities.
- Evaluate potential opportunities and threats associated with emerging technologies, regulations, and industry practices.

ISACA

4

DOMAIN 5 TOPICS

Information Asset Security and Control

- Introduction
- Information Asset Security Frameworks, Standards, and Guidelines
- Privacy Principles
- Physical Access and Environmental Controls
- Identity and Access Management
- Network and End-point Security
- Data Classification
- Data Encryption and Encryption-related Techniques
- Public Key Infrastructure (PKI)
- Web-based Communication Technologies
- Virtualized Environments
- Mobile, Wireless, and Internet-of-Things (IOT) Devices

Security Event Management

- Security Awareness Training and Programs
- Information System Attack Methods and Techniques
- Security Testing Tools and Techniques
- Security Monitoring Tools and Techniques
- Incident Response Management
- Evidence Collection and Forensics

5

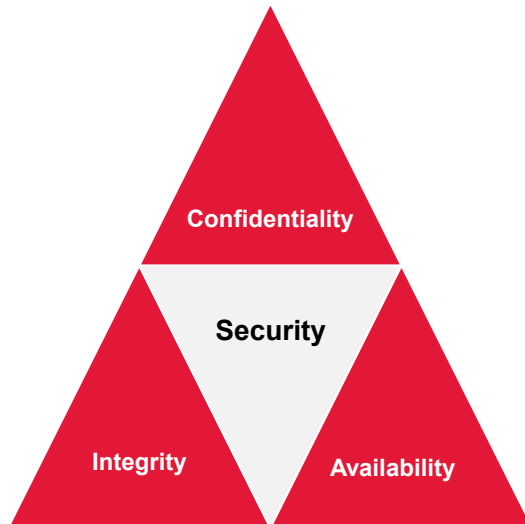
ISACA

5



6

ENSURE CONFIDENTIALITY, INTEGRITY AND AVAILABILITY



7

7

INFORMATION ASSET SECURITY FRAMEWORKS, STANDARDS AND GUIDELINES

ISACA

8

AUDITING THE INFORMATION SECURITY MANAGEMENT FRAMEWORK

Reviewing Written Policies, Procedures and Standards

Formal Security Awareness and Training

Data Ownership

Data Owners

Data Custodians

Security Administrator

New IT Users

Data Users

Documented Authorizations

Terminated Employee Access

Security Baselines

Access Standards

9

ISACA

9

PRIVACY PRINCIPLES

10

ISACA

10

PRIVACY PRINCIPLES GOOD PRACTICE

Privacy should be considered from the outset and be built in by design. It should be systematically built into policies, standards and procedures from the beginning.

Private data should be collected fairly in an open, transparent manner. Only the data required for the purpose should be collected in the first instance.

Private data should be kept securely throughout their life cycle.

Private data should only be used and/or disclosed for the purpose for which they were collected.

Private data should be accurate, complete and up to date.

Private data should be deleted when they are no longer required.

11

ISACA

11

PURPOSE OF PRIVACY IMPACT ANALYSIS

Pinpoint the nature of personally identifiable information associated with business processes.

Document the collection, use, disclosure and destruction of personally identifiable information.

Ensure that accountability for privacy issues exists.

Identify legislative, regulatory and contractual requirements for privacy.

Be the foundation for informed policy, operations and system design decisions based on an understanding of privacy risk and the options available for mitigating that risk.

12



12

IS AUDIT TO ASSURE COMPLIANCE PRIVACY POLICY, LAWS AND OTHER REGULATIONS

Identify and understand compliance requirements regarding privacy from laws, regulations and contract agreements. Depending on the assignment, IS auditors may need to seek legal or expert opinion on these.

Review management's privacy policy to ascertain whether it takes into consideration the requirement of these privacy laws and regulations.

Check whether personal sensitive data are correctly managed in respect to these requirements.

Verify that the correct security measures are adopted.

13



13

AUDIT CONSIDERATIONS FOR PRIVACY

Choice and consent

Legitimate purpose specification and use limitation

Personal information and sensitive information life cycle

Accuracy and quality

Openness, transparency and notice

Individual participation

Accountability

Security safeguards

Monitoring, measuring and reporting

Preventing harm

Third-party/vendor management

Breach management

Security and privacy by design

Free flow of information and legitimate restriction

14

ISACA

14

PHYSICAL ACCESS AND ENVIRONMENTAL CONTROLS

ISACA

15

PHYSICAL ACCESS AND ENVIRONMENTAL CONTROLS

Evaluate the design, implementation, maintenance, monitoring and reporting of physical and environmental controls to determine whether information assets are adequately safeguarded.

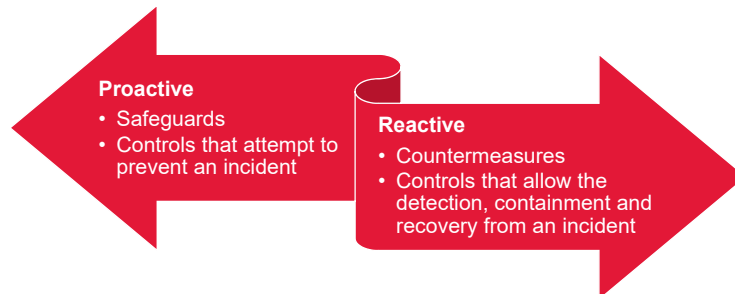


16

SECURITY CONTROLS

An effective control is one that prevents, detects, and/or contains an incident and enables recovery from an event.

Controls can be:



ISACA

17

MANAGERIAL, TECHNICAL AND PHYSICAL CONTROLS

Managerial Controls

- Related to the oversight, reporting, procedures and operation of a process.

Technical

- Controls provided through the use of technology, piece of equipment or device.

Physical

- Devices installed to physically restrict access to a facility or hardware.

18

ISACA

18

PHYSICAL ACCESS ISSUES

- Unauthorized entry
- Damage, vandalism or theft to equipment or documents
- Copying or viewing of sensitive or copyrighted information
- Alteration of sensitive equipment and information
- Public disclosure of sensitive information
- Abuse of data processing resources
- Blackmail
- Embezzlement



19

PHYSICAL CONTROLS EXAMPLES

Door locks (cipher, biometric, bolted, electronic)	Controlled visitor access
Manual or electronic logging	Computer workstation locks
Identification badges	Controlled single entry point
CCTV	Alarm system
Security guards	Deadman doors

20

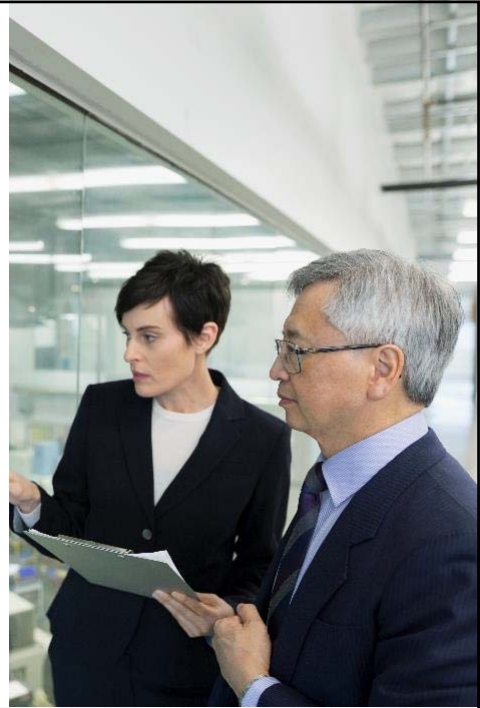
ISACA

20

PHYSICAL ACCESS AUDIT

The IS auditor should begin with a tour of the site and then test physical safeguards.

Physical tests can be completed through visual observations and review of documents such as fire system tests, inspection tags and key lock logs.



21

PHYSICAL ACCESS AUDIT (CONT'D)

The test should include all paths of physical entry, as well as the following locations:

- Computer and printer rooms
- UPS/generator
- Operator consoles
- Computer storage rooms
- Communication equipment
- Offsite backup storage facility
- Media storage

ISACA

22

ENVIRONMENTAL EXPOSURES

Power failure

- Total failure (blackout)
- Severely reduced voltage (brownout)
- Sags, spikes and surges
- Electromagnetic interference (EMI)

Water damage/flooding

Manmade concerns

- Terrorist threats/attacks
- Vandalism
- Equipment failure

ISACA

23

ENVIRONMENTAL CONTROLS

Environmental exposures should be afforded the same level of protection as other types of exposures. Possible controls include:

Alarm control panels	Water detectors	Fire extinguishers	Fire alarms and smoke detectors
Fire suppression systems	Fireproof and fire-resistant building and office materials	Strategically located computer rooms	Electrical surge protectors
Uninterruptible power supply/generator	Power leads from two substations	Emergency power-off switch	Documented and tested BCPs and emergency evacuation plans

ISACA

24

ENVIRONMENTAL CONTROL AUDIT

The IS auditor should first establish the environmental risk by assessing the location of the data center.

In addition, the IS auditor should verify that the following safeguards are in place:

- Water and smoke detectors
- Strategic and visible location of handheld fire extinguishers
- Fire suppression system documentation and inspection by fire department
- UPS/generator test reports
- Electrical surge protectors
- Documentation of fireproof building materials, use of redundant power lines and wiring located in fire-resistant panels
- Documented and tested emergency evacuation plans and BCPs
- Humidity and temperature controls

ISACA

25



ACTIVITY

The directory of facility operations has asked the IS audit team to perform a gap analysis of the current policies and procedures at the headquarters building that also houses the primary data center. You find that policies and procedures are currently focused on operations and maintenance contracting activities.

What is an example of an environmental exposure that controls should be in place to mitigate?

What would be a means to perform penetration testing of physical controls?

26

DISCUSSION QUESTION

Which of the following environmental controls is appropriate to protect computer equipment against short-term reductions in electrical power?

- A. Power line conditioners
- B. Surge protective devices
- C. Alternative power supplies
- D. Interruptible power supplies



27

DISCUSSION QUESTION

An IS auditor is reviewing the physical security measures of an organization. Regarding the access card system, the IS auditor should be **MOST** concerned that:

- A. nonpersonalized access cards are given to the cleaning staff, who use a sign-in sheet but show no proof of identity.
- B. access cards are not labeled with the organization's name and address to facilitate easy return of a lost card.
- C. card issuance and rights administration for the cards are done by different departments, causing unnecessary lead time for new cards.
- D. the computer system used for programming the cards can only be replaced after three weeks in the event of a system failure.



28

IDENTITY AND ACCESS MANAGEMENT

ISACA

29

SECURITY OBJECTIVES

Security objectives to meet an organization's business requirements should ensure the following:

- Continued availability of information systems and data
- Integrity of the information stored on computer systems and while in transit
- Confidentiality of sensitive data is preserved while stored and in transit
- Conformity to applicable laws, regulations and standards
- Adherence to trust and obligation requirements in relation to any information relating to an identified or identifiable individual (i.e., data subject) in accordance with internal privacy policy or applicable privacy laws and regulations
- Adequate protection for sensitive data while stored and when in transit, based on organizational requirements

ISACA

30

SYSTEM ACCESS PERMISSION

System access permission generally refers to a technical privilege, such as the ability to read, create, modify or delete a file or data; execute a program; or open or use an external connection.

System access to computerized information resources is established, managed and controlled at the physical and/or logical level.

Physical access controls

- Restrict the entry and exit of personnel to an area, such as an office building, suite, data center or room, containing information processing equipment.

Logical access controls

- Restrict the logical resources of the system (transactions, data, programs, applications) and are applied when the subject resource is needed.

ISACA

31

SYSTEM ACCESS REVIEWS

Roles should be assigned by the information owner or manager.

Access authorization should be regularly reviewed to ensure they are still valid.

The IS auditor should evaluate the following criteria for defining permissions and granting access:

- Need-to-know
- Accountability
- Traceability
- Least privilege
- SoD

ISACA

32

INFORMATION SECURITY AND EXTERNAL PARTIES

Identification of Risk Related to External Parties

- Access by external parties to the organization's information should not be provided until the appropriate controls have been implemented and, where feasible, a contract has been signed defining the terms and conditions for the connection or access and the working arrangement.
- External parties might put information at risk if their security management is inadequate.
- NOTE – Controls should be identified and applied to administer external party access to information processing facilities.

Addressing Security When Dealing With Customers

- Asset protection and access control policies apply to customers to meet security requirements of assets.

33

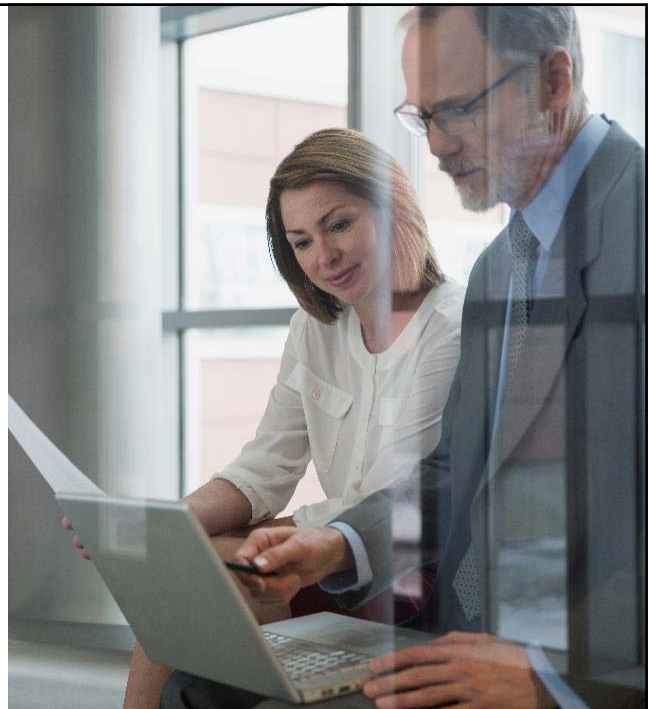
ISACA

33

THIRD-PARTY ACCESS

Third-party access to an organization's information processing facilities and processing and communication of information must be controlled.

These controls must be agreed to and defined in a contract with the third party.



34

THIRD-PARTY ACCESS RECOMMENDED CONTRACT TERMS

Compliance with the organization's information security policy

A clear reporting structure and agreed reporting formats

A clear and specified process for change management

An access control policy

Arrangements for reporting, notifying and investigating information security incidents and security breaches

Service continuity requirements

The right to monitor and revoke any activity related to the organization's assets



35

HUMAN RESOURCES SECURITY AND THIRD PARTIES

Security roles and responsibilities of employees, contractors and third-party users should be defined and documented in accordance with the organization's information security policy.

Screening

- All candidates for employment, contractors or third-party users should be subject to background verification checks.

Removal of Access Rights

- The access rights of all employees, contractors and third-party users to information and information processing facilities should be removed upon termination of their employment, contract or agreement, or adjusted upon change.

ISACA

36

LOGICAL ACCESS

Logical access is the ability to interact with computer resources granted using identification, authentication and authorization.

Logical access controls are the primary means used to manage and protect information assets.

IS auditors should be able to analyze and evaluate the effectiveness of a logical access control in accomplishing information security objectives and avoiding losses resulting from exposures.

These exposures can result in minor inconveniences to a total shutdown of computer functions.

37



37

LOGICAL ACCESS EXPOSURES

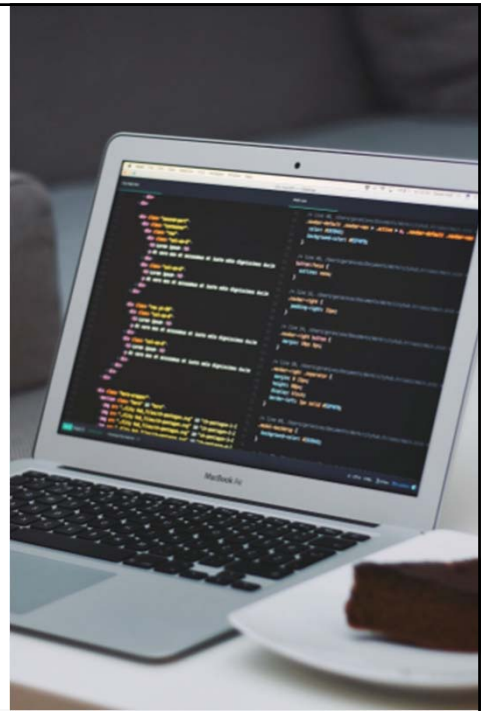
Data leakage

- Involves siphoning or leaking information out of the computer.

Computer shutdown

- Initiated through terminals or personal computers connected directly (online) or remotely (via the Internet) to the computer.

38



38

PATHS OF LOGICAL ACCESS

- Direct path
- Local network
- Remote access



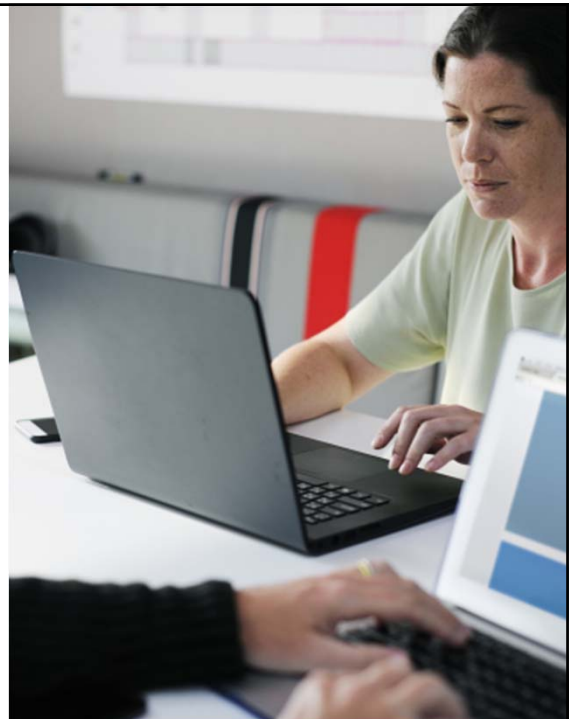
39

ACTIVITY

During your ERP upgrade audit, you identify the following findings:

- Logical access controls to the administrative application server accounts are comprised of non-complex single factor authentication with password length required to be six characters changed every 360 days.
- There was no policy in place for classification of information assets.

What is the purpose of assigning classes or levels of sensitivity and criticality to information resources and establishing specific security rules for each class?

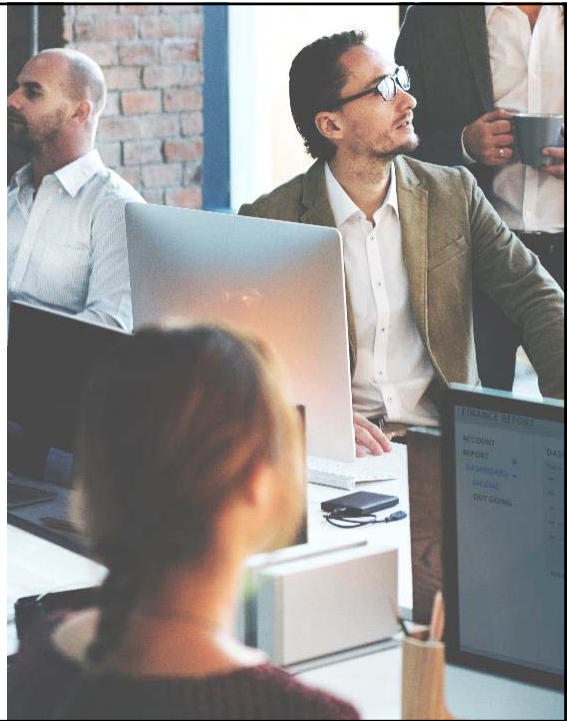


40

DISCUSSION QUESTION

An information security policy stating that “the display of passwords must be masked or suppressed” addresses which of the following attack methods?

- A. Piggybacking
- B. Dumpster diving
- C. Shoulder surfing
- D. Impersonation



41

DISCUSSION QUESTION

With the help of a security officer, granting access to data is the responsibility of:

- A. data owners.
- B. programmers.
- C. system analysts.
- D. librarians.



42

ACCESS CONTROL SOFTWARE

Access control software is used to prevent the unauthorized access and modification to an organization's sensitive data and the use of system critical functions.

Access controls must be applied across all layers of an organization's IS architecture, including networks, platforms or OSs, databases and application systems.

Each access control usually includes:

- Identification and authentication
- Access authorization
- Verification of specific information resources
- Logging and reporting of user activities

ISACA

43

ACCESS CONTROL SOFTWARE FUNCTIONS

General operating and/or application systems access control functions

- Create or change user profiles.
- Assign user identification and authentication.
- Apply user logon limitation rules.
- Notification concerning proper use and access prior to initial login.
- Create individual accountability and auditability by logging user activities.
- Establish rules for access to specific information resources (e.g., system-level application resources and data).
- Log events.
- Report capabilities.

Database and/or application-level access control functions

- Create or change data files and database profiles.
- Verify user authorization at the application and transaction level.
- Verify user authorization within the application.
- Verify user authorization at the field level for changes within a database.
- Verify subsystem authorization for the user at the file level.
- Log database/data communications access activities for monitoring access violations.

ISACA

44

ACCESS CONTROL TYPES

Mandatory access controls (MACs)

- Logical access control filters used to validate access credentials
- Cannot be controlled or modified by normal users or data owners
- Act by default
- Prohibitive; anything that is not expressly permitted is forbidden

Discretionary access controls (DACs)

- Logical access controls that may be configured or modified by the users or data owners
- Cannot override MACs
- Act as an additional filter, prohibiting still more access with the same exclusionary principle

ISACA

45

IDENTIFICATION AND AUTHENTICATION

Logical access identification and authentication (I&A) is the process of establishing and proving a user's identity.

For most systems, I&A is the first line of defense because it prevents unauthorized people (or unauthorized processes) from entering a computer system or accessing an information asset.

ISACA

46

IDENTIFICATION AND AUTHENTICATION (CONT'D)

Some common I&A vulnerabilities include:

- Weak authentication methods
- Use of simple or easily guessed passwords
- The potential for users to bypass the authentication mechanism
- The lack of confidentiality and integrity for the stored authentication information
- The lack of encryption for authentication and protection of information transmitted over a network
- The user's lack of knowledge on the risk associated with sharing authentication elements

ISACA

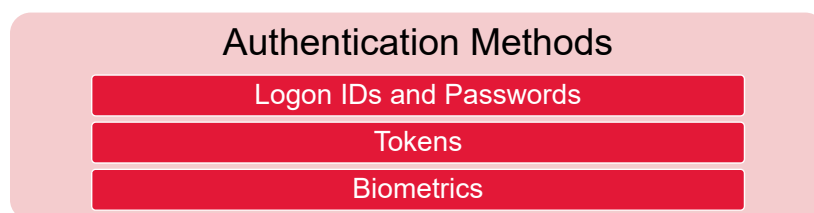
47

AUTHENTICATION METHODS

Multifactor authentication is the combination of more than one authentication method.

Single sign-on (SSO) is the process for consolidating all of an organization's platform-based administration, authentication and authorization functions into a single centralized administrative function.

The IS auditor should be familiar with the organization's authentication policies.



ISACA

48

AUTHORIZATION

Authorization refers to the access rules that specify who can access what.

Access control is often based on least privilege, which refers to the granting to users of only those accesses required to perform their duties.

The IS auditor needs to know what can be done with the access and what is restricted.

The IS auditor must review access control lists (ACLs). An ACL is a register of users who have permission to use a particular system and the types of access permitted.

ISACA

49

AUTHORIZATION ISSUES

Risks	Controls
• Denial of service • Malicious third parties • Misconfigured communications software • Misconfigured devices on the corporate computing infrastructure • Host systems not secured appropriately • Physical security issues over remote users' computers	• Policy and standards • Proper authorizations • Identification and authentication mechanisms • Encryption tools and techniques such as use of a VPN • System and network management

ISACA

50

SYSTEM LOGS

Audit trail records should be protected by strong access controls to help prevent unauthorized access.

The IS auditor should ensure that the logs cannot be tampered with, or altered, without leaving an audit trail.

When reviewing or performing security access follow-up, the IS auditor should look for:

- Patterns or trends that indicate abuse of access privileges, such as concentration on a sensitive application
- Violations (such as attempting computer file access that is not authorized) and/or use of incorrect passwords

ISACA

51

ACCESS CONTROL LISTS

To provide security authorizations for the files and facilities listed previously, logical access control mechanisms use access authorization tables, also referred to as access control lists (ACLs) or access control tables. ACLs refer to a register of:

- Users (including groups, machines, processes) who have permission to use a particular system resource
- The types of access permitted

When a user changes job roles within an organization, often their old access rights are not removed before adding their new required accesses.

Without removing the old access rights, there could be a potential SoD issue.

ISACA

52

LOGICAL ACCESS SECURITY ADMINISTRATION

Software controls over access to the computer, data files and remote access to the network should be implemented.

The physical control environment should be as secure as possible, with additions such as lockable terminals and a locked computer room.

Access from remote locations via modems and laptops to other microcomputers should be controlled appropriately.

Opportunities for unauthorized people to gain knowledge of the system should be limited by implementing controls over access to system documentation and manuals.

Controls should exist for data transmitted from remote locations such as sales in one location that update accounts receivable files at another location. The sending location should transmit control information, such as transaction control totals, to enable the receiving location to verify the update of its files. When practical, central monitoring should ensure that all remotely processed data have been received completely and updated accurately.

When replicated files exist at multiple locations, controls should ensure that all files used are correct and current and, when data are used to produce financial information, that no duplication arises.

53

ISACA

53

REMOTE ACCESS SECURITY

Remote access risk includes:

- Denial of service (DoS)
- Malicious third parties
- Misconfigured communications software
- Misconfigured devices
- Host systems not secured appropriately
- Physical security issues over remote users' computers

Remote access controls include:

- Policy and standards
- Proper authorizations
- Identification and authentication mechanisms
- Encryption tools and techniques such as use of a VPN
- System and network management

54

ISACA

54

AUDIT LOGGING IN MONITORING SYSTEM ACCESS

Access Rights to System Logs

Access rights to system logs for security administrators to perform the previous activities should be strictly controlled.

A periodic review of system-generated logs can detect security problems, including attempts to exceed access authority or gain system access during unusual hours.

Tools for Audit Trail (Logs)

Analysis

Audit reduction tools

Trend/variance-detection tools

Attack-signature-detection tools

SIEM systems

IS Audit Review

The IS auditor should ensure that the logs cannot be tampered with, or altered, without leaving an audit trail.

When reviewing or performing security access follow-up, the IS auditor should look for:

- Patterns or trends that indicate abuse of access privileges, such as concentration on a sensitive application
- Violations (such as attempting computer file access that is not authorized) and/or use of incorrect passwords

55

ISACA

55

AUDITING LOGICAL ACCESS

Obtain a general understanding of the security risk facing information processing, through a review of relevant documentation, inquiry, observation, risk assessment and evaluation techniques.

Document and evaluate controls over potential access paths into the system to assess their adequacy, efficiency and effectiveness by reviewing appropriate hardware and software security features and identifying any deficiencies or redundancies.

Test controls over access paths to determine whether they are functioning and effective by applying appropriate audit techniques.

Evaluate the access control environment to determine if the control objectives are achieved by analyzing test results and other audit evidence.

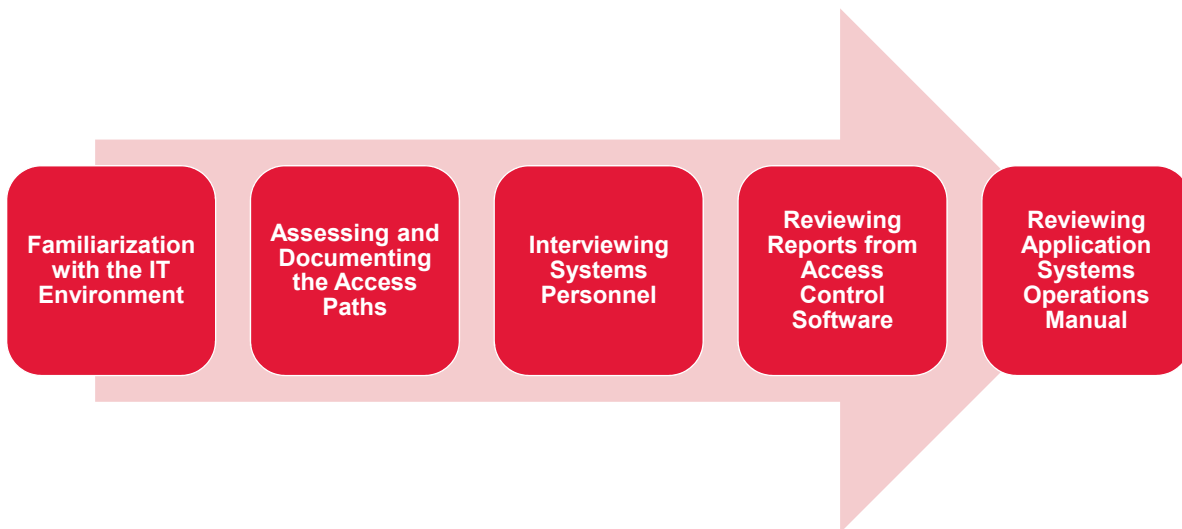
Evaluate the security environment to assess its adequacy by reviewing written policies, observing practices and procedures, and comparing them with appropriate security standards or practices and procedures used by other organizations.

56

ISACA

56

AUDITING LOGICAL ACCESS PROCESS



57

ISACA

57

DATA LEAKAGE

Data leakage involves the unauthorized transfer of sensitive or proprietary information from an internal network to the outside world.

Data leak prevention is a suite of technologies and associated processes that locate, monitor and protect sensitive information from unauthorized disclosure.

DLPs have three key objectives:

- Locate and catalog sensitive information stored throughout the enterprise.
- Monitor and control the movement of sensitive information across enterprise networks.
- Monitor and control the movement of sensitive information on end-user systems.

ISACA

58

DLP SOLUTIONS

- Data at rest
- Data in motion
- Data in use
- Policy creation and management
- Directory services integration
- Workflow management
- Backup and restore
- Reporting
- DLP risk, limitations and considerations



59

NETWORK AND END-POINT SECURITY

ISACA

60

THE OPEN SYSTEMS INTERCONNECTION (OSI) MODEL

The OSI model defines groups of functionality required for network computers into layers, described as follows:

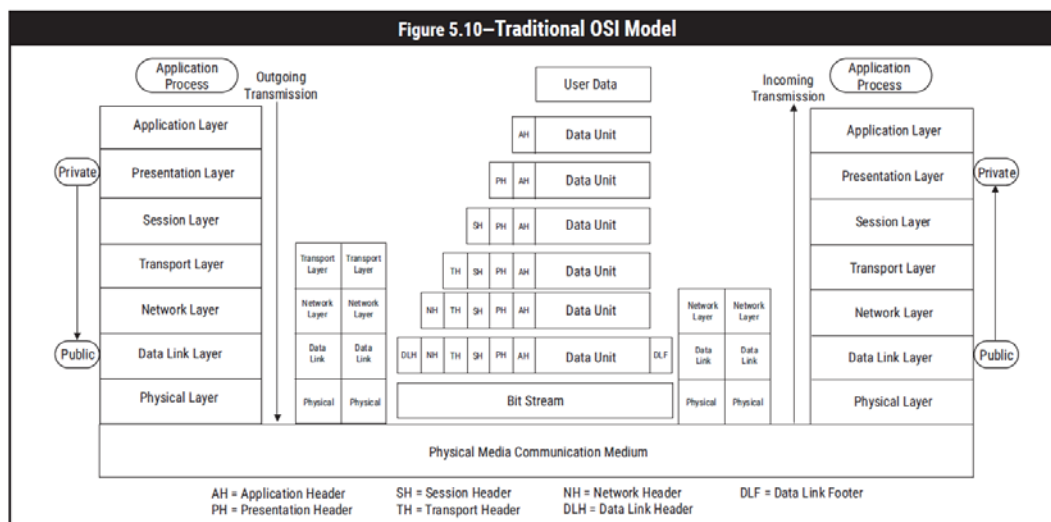
1. Physical layer—Manages signals among network systems
2. Data link layer—Divides data into frames that can be transmitted by the physical layer
3. Network layer—Translates network addresses and routes data from sender to receiver
4. Transport layer—Ensures that data are transferred reliably in the correct sequence
5. Session layer—Coordinates and manages user connections
6. Presentation layer—Formats, encrypts and compresses data
7. Application layer—Mediates between software applications and other layers of network services

61

ISACA

61

TRADITIONAL OSI MODEL



62

ISACA

62

ASSOCIATED LAN RISKS

Loss of data and program integrity through unauthorized changes

Lack of current data protection through inability to maintain version control

Exposure to external activity through poor user verification and potential public network access from remote connections

Virus and worm infection

Improper disclosure of data because of general access rather than need-to-know access provisions

Illegal access by impersonating or masquerading as a legitimate

LAN user

Internal user sniffing

Internal user spoofing

Lack of enabled detailed automated logs of activity

Destruction of the logging and auditing data

63

ISACA

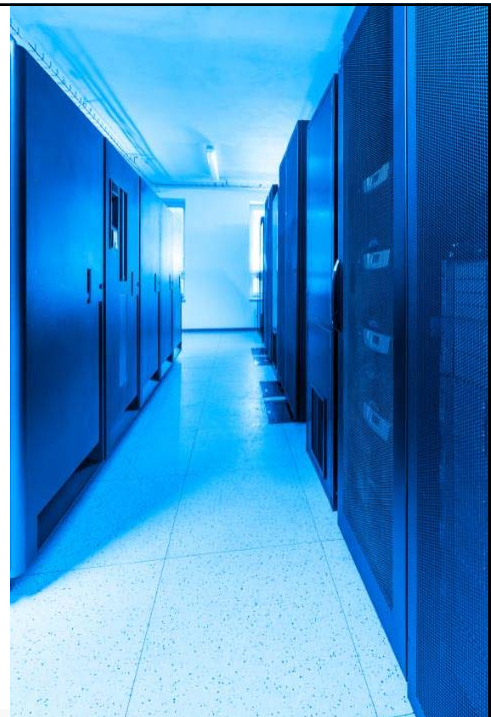
63

IS AUDIT'S ROLE IN LAN TECHNOLOGY

To gain a full understanding of the LAN, the IS auditor should identify and document the following:

- Users or groups with privileged access rights
- LAN topology and network design
- LAN administrator/LAN owner
- Functions performed by the LAN administrator/owner
- Distinct groups of LAN users
- Computer applications used on the LAN
- Procedures and standards relating to network design, support, naming conventions and data security

64



64

NETWORK INFRASTRUCTURE SECURITY

The IS auditor should be familiar with risk and exposures related to network infrastructure.

Network control functions should:

- Be performed by trained professionals, and duties should be rotated on a regular basis.
- Maintain an audit trail of all operator activities.
- Restrict operator access from performing certain functions.
- Periodically review audit trails to detect unauthorized activities.
- Document standards and protocols.
- Analyze workload balance, response time and system efficiency.
- Encrypt data, where appropriate, to protect messages from disclosure during transmission.

ISACA

65

VIRTUALIZATION

IS auditors need to understand the advantages and disadvantages of virtualization to determine whether the enterprise has considered the applicable risk in its decision to adopt, implement and maintain this technology.

Some common advantages and disadvantages include:

Advantages	Disadvantages
• Decreased server hardware costs. • Shared processing capacity and storage space. • Decreased physical footprint. • Multiple versions of the same OS.	• Inadequate host configuration could create vulnerabilities that affect not only the host, but also the guests. • Data could leak between guests. • Insecure protocols for remote access could result in exposure of administrative credentials.

ISACA

66

CLIENT-SERVER SECURITY

A client-server is a group of computers connected by a communications network in which the client is the requesting machine and the server is the supplying machine.

Several access routes exist in a client-server environment.



67

IS AUDITOR ROLE IN CLIENT-SERVER SECURITY

The IS auditor should ensure that:

- Application controls cannot be bypassed.
- Passwords are always encrypted.
- Access to configuration or initialization files is kept to a minimum.
- Access to configuration or initialization files are audited.

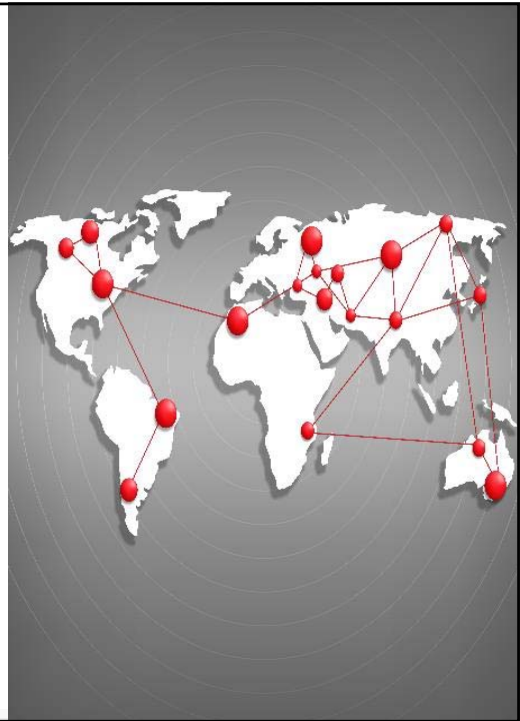
ISACA

68

WIRELESS SECURITY

Wireless security requirements include the following:

- **Authenticity**—A third party must be able to verify that the content of a message has not been changed in transit.
- **Nonrepudiation**—The origin or the receipt of a specific message must be verifiable by a third party.
- **Accountability**—The actions of an entity must be uniquely traceable to that entity.
- **Network availability**—The IT resource must be available on a timely basis to meet mission requirements or to avoid substantial losses.



69

INTERNET SECURITY

The IS auditor must understand the risk and security factors needed to ensure that proper controls are in place when a company connects to the Internet.

Network attacks involve probing for network information.

- Examples of passive attacks include network analysis, eavesdropping and traffic analysis.

ISACA

70

INTERNET SECURITY (CONT'D)

Once enough network information has been gathered, an intruder can launch an actual attack against a targeted system to gain control.

- Examples of active attacks include denial of service (DoS), phishing, unauthorized access, packet replay, brute force attacks and email spoofing.

The IS auditor should have a good understanding of the following types of firewalls:

- Packet filtering
- Application firewall systems
- Stateful inspections

ISACA

71

INTERNET SECURITY (CONT'D)

The IS auditor should also be familiar with common firewall implementations, including:

- Screened-host firewall
- Dual-homed firewall
- Demilitarized zone (DMZ) or screened-subnet firewall

The IS auditor should be familiar with the types, features and limitations of intrusion detection systems and intrusion prevention systems.



72

FIREWALLS

A firewall is a system or combination of systems that enforces a boundary between two or more networks.

Typically forms a barrier between a secure and an open environment such as the Internet, apply rules to control the type of networking traffic flowing in and out.

Most commercial firewalls are built to handle commonly used Internet protocols.

73

ISACA

73

FIREWALL FEATURES

There are different types of firewalls, but most of them enable organizations to:

- Filter ingoing and outgoing traffic
- Can block access to particular sites on the Internet
- Limit traffic on an organization's public services segment to relevant addresses and ports
- Prevent certain users from accessing certain servers or services
- Monitor and record communications between an internal and an external network in order to investigate network penetrations or detect internal subversion
- Encrypt packets sent between different locations within an organization by creating a Virtual Private Network (VPN) over the Internet (i.e., IPSec, VPN tunnels)

ISACA

74

74

FIREWALL TECHNOLOGIES

- Packet Filters
- Stateful Inspection
- Application Proxy
- Next Generation Firewall



75

75

PACKET-FILTERING FIREWALL MODEL

A first-generation firewall, in packet filtering, a screening router examines the header of every data packet traveling between the Internet and the organization's network.

Packet headers contain:

- Information, including the IP address of the sender and receiver
- The port numbers (application or service) authorized to use the information transmitted
- Based on that information, the router recognizes the kind of Internet service being used to send the data and the identities of the sender and receiver of the data.
- With this, the router can prevent certain packets from being sent between the Internet and the corporate network.

ISACA

76

76

PACKET-FILTERING FIREWALLS

Advantages

- Simplicity of one network “choke point”
- Minimal impact on network performance
- Inexpensive or free

Disadvantages

- Vulnerable to attacks from improperly configured files
- Vulnerable to attacks tunneled over permitted services
- All private network systems vulnerable when a single packet filtering router is compromised

ISACA

77

77

COMMON ATTACKS AGAINST PACKET-FILTERING FIREWALLS

IP spoofing

- The attacker fakes the IP address of either an internal network host or a trusted network host, so the packet being sent may pass the rule base of the firewall and penetrate the system perimeter.

Source routing specification

- The attacker defines the route the IP packet takes such that it will bypass the firewall.
- This type of attack centers around the routing that an IP packet must take when it traverses the Internet from the source host to the destination host.

Miniature fragment attack

- The attacker fragments the IP packet pushes smaller packets through the firewall.
- This type of attack relies on only the first sequence of fragmented packets being examined, with the hope that others will be able to pass without review.

78

ISACA

78

APPLICATION FIREWALL SYSTEMS

Application firewall systems allow information to flow between systems but do not allow the direct exchange of packets.

There are two types of application firewall systems:

Application-level gateways—Systems that analyze packets through a set of proxies—one for each service.

- The implementation of multiple proxies impacts network performance, so when network performance is a concern, a circuit-level gateway may be a better choice.

Circuit-level gateways—Systems that use one proxy server for all services.

- These are more efficient and also operate at the application level.
- TCP and UDP sessions are validated, typically through a single, general-purpose proxy before opening a connection.

Note that commercially, circuit-level gateways are quite rare.

79

ISACA

79

APPLICATION FIREWALLS

Advantages

- Provide security for commonly used protocols
- Generally hide the network from outside, untrusted networks
- Ability to protect the entire network by limiting break-ins to the firewall itself
- Ability to examine and secure program code

Disadvantages

- Poor performance and scalability as Internet usage grows

ISACA

80

80

STATEFUL INSPECTION SYSTEMS

Also referred to as dynamic packet filtering, a stateful inspection system tracks the destination IP address of each packet that leaves the organization's internal network.

The stateful system maps the source IP address of an incoming packet with a list of destination IP addresses that is maintained and updated.

When a response to a packet is received, its record is referenced to determine whether the incoming message was made in response to a request that the organization sent out.

This approach prevents any attack initiated and originated by an outsider.

ISACA

81

STATEFUL INSPECTION FIREWALLS

Advantages

- Provide greater control over the flow of IP traffic
- Greater efficiency in comparison to CPU-intensive, full-time application firewall systems

Disadvantages

- Complex to administer

ISACA

82

82

STATELESS VS. STATEFUL FIREWALLS

Stateless filtering does not keep the state of ongoing TCP connection sessions.

- This contrasts with the action of stateful systems, which keep track of TCP connections.

The stateless system has no memory of what source port numbers a session's client selected.

- Stateless firewalls are quicker, but less sophisticated than stateful firewalls.

Because UDP traffic is stateless, applications that require UDP to operate from the Internet into a corporate network should be:

- Used sparingly
- Implemented with alternate controls

ISACA

83

FIREWALL IMPLEMENTATIONS

Firewall implementations can take advantage of the functionality available in a variety of firewall designs to provide a robust and layered approach to protect an organization's information assets.

Commonly used implementations available today include:

- Screened-host firewall—Implements basic network layer security (packet filtering) and application server security (proxy services)
- Dual-homed firewall—Has two or more network interfaces, each of which is connected to a different network.
- Demilitarized zone (DMZ) or screened-subnet firewall

ISACA

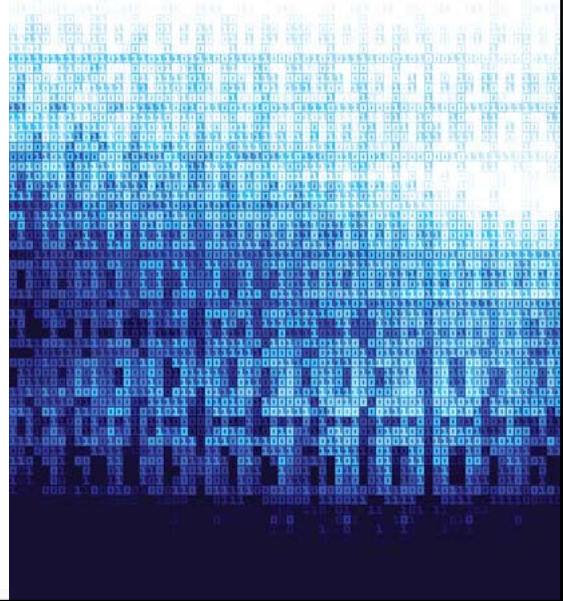
84

FIREWALL IMPLEMENTATIONS (CONTINUED)

Another commonly used firewall implementation is the Demilitarized zone (DMZ) or screened-subnet firewall.

This is a small, isolated network for an organization's public servers, bastion host information servers and modem pools.

- The DMZ connects the untrusted network to the trusted network, but exists in its own independent space to limit access and availability of resources.

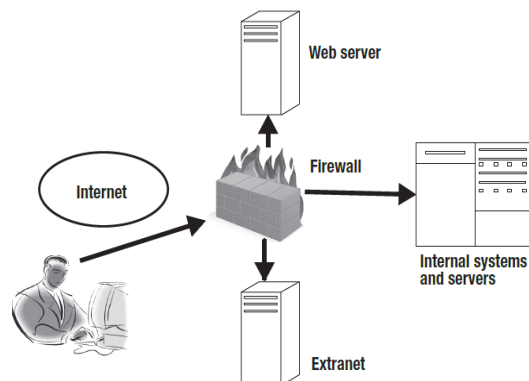


85

DMZ FIREWALL BENEFITS

The key benefits of the DMZ system are:

- An intruder must penetrate three separate devices
- Private network addresses are not disclosed to the Internet
- Internal systems do not have direct access to the Internet



ISACA

86

FIREWALL ISSUES

Configuration errors

Monitoring demands

Policy maintenance

Vulnerability to application-based and input-based attacks

ISACA

87

87

FIREWALL PLATFORMS

Firewalls may be implemented using hardware, software or virtual platforms.

Implementing hardware provides performance with minimal system overhead.

- These are not as flexible or scalable as software-based firewalls.

Software-based firewalls are generally slower with significant systems overhead.

- They are flexible and may include additional services such as virus protection.

When server-based firewalls are used, operating systems in servers are often vulnerable to attacks.

- When attacks on operating systems succeed, the firewall may be compromised.

An appliance is a device with all software and configurations pre-setup on a physical server that is plugged in between two networks. It is generally better to use appliances, rather than normal servers, for the firewall.

ISACA

88

NEXT GENERATION FIREWALLS (NGFW)

NGFWs are firewalls aimed at addressing two key limitations found in earlier firewalls:

- The firewall's inability to inspect packet payload
- The firewall's inability to distinguish between types of web traffic

An NGFW is an adaptive network security system capable of detecting and blocking sophisticated attacks.

These perform traditional functions, such as:

- Packet filtering
- Stateful inspection
- Network address translation (NAT)
- Introduce application awareness
- Incorporate deep packet inspection (DPI) technology
- Offer varying degrees of integrated threat protection

ISACA

89

WEB APPLICATION FIREWALLS (WAF)

A web application firewall (WAF) is a server plug-in, appliance or additional filter that can be used to apply rules to a specific web application (usually to an HTTP conversation).

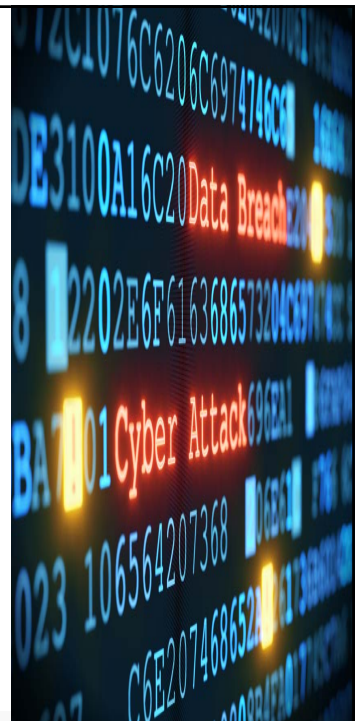
The WAF operates at higher levels in the OSI model, generally at level 7.

In contrast, network firewalls operate at level 3 or level 4.

A WAF may be customized to identify and block many types of attacks, but customization requires effort.

When changes to the application are made, the WAF rules need changes as well.

90



90

DEVELOPMENT AND AUTHORIZATION OF NETWORK CHANGES

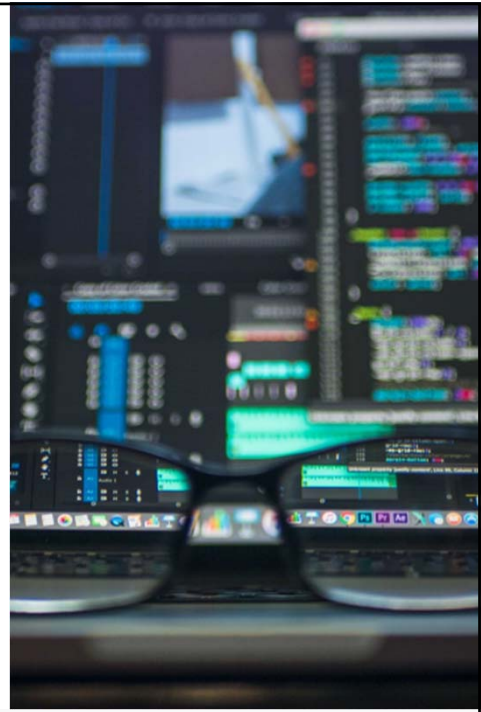
The IS auditor can test this change control by:

- Sampling recent change requests, looking for appropriate authorization and matching the request to the actual network device
- Matching recent network changes, such as new telecommunication lines, to added terminals and authorized change requests

As an added control, the IS auditor should determine who can access the network change software.

This access should be restricted to senior network administrators.

91

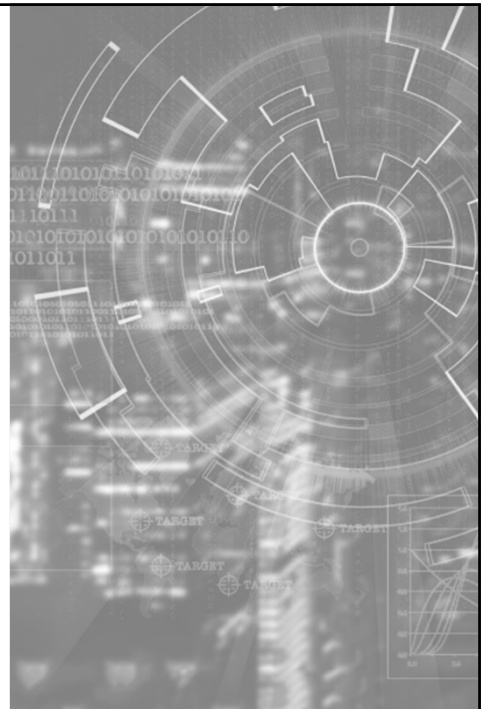


91

SHADOW IT

Shadow IT is an application, tool, service or system that is used within an organization to collaborate, develop software, share content, store and manipulate data or serve any number of other purposes without having been reviewed, tested, approved, implemented or secured by the organization's IT and/or information security functions, in accordance with written policies and procedures.

92



92

SHADOW IT CONTROLS

IT department as a service-delivery organization

IT budgeting and procurement

IT system consolidation (where feasible)

User access and administrative rights

User education

User activity monitoring

User data exchange

Shadow IT policy—A shadow IT policy that aligns with business objectives and support security requirements.

ISACA

93

ACTIVITY

You have been assigned to a network architecture review. This is a large multi-campus wide area network that uses the following technologies:

- External
 - Standard ISP provided T1s and OS3
 - VerSprinAT & Bell MPLS
 - Satellite communications
 - Point to Point RF
- Internal
 - WIFI for corporate and guests
 - Wired with fiber backbone

When performing an audit of the network infrastructure, what document should the IS auditor review?



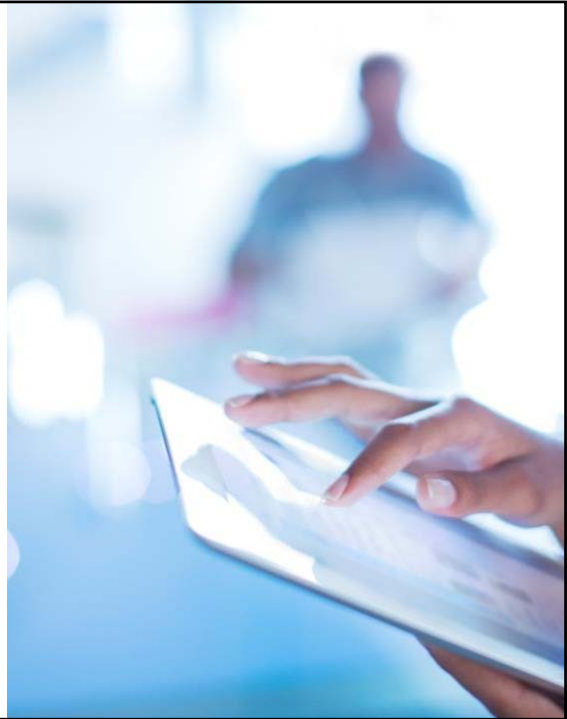
94



ACTIVITY

The CIO and CISO state their objective is to prevent and detect computer attacks that could result in proprietary or confidential data being stolen or modified.

What would be a risk specific to wireless networks?



95

DATA CLASSIFICATION

ISACA

96

DATA CLASSIFICATION

In order to have effective controls, organizations must have a detailed inventory of information assets.

Most organizations use a classification scheme with three to five levels of sensitivity.

Data classification provides the following benefits:

- Defines level of access controls
- Reduces risk and cost of over- or under-protecting information resources
- Maintains consistent security requirements
- Enables uniform treatment of data by applying level-specific policies and procedures
- Identifies who should have access

ISACA

97

DATA CLASSIFICATION (CONT'D)

The information owner should decide on the appropriate classification, based on the organization's data classification and handling policy.

Data classification should define:

- The importance of the information asset
- The information asset owner
- The process for granting access
- The person responsible for approving the access rights and access levels
- The extent and depth of security controls

Data classification must also take into account legal, regulatory, contractual and internal requirements for maintaining privacy, confidentiality, integrity and availability.

ISACA

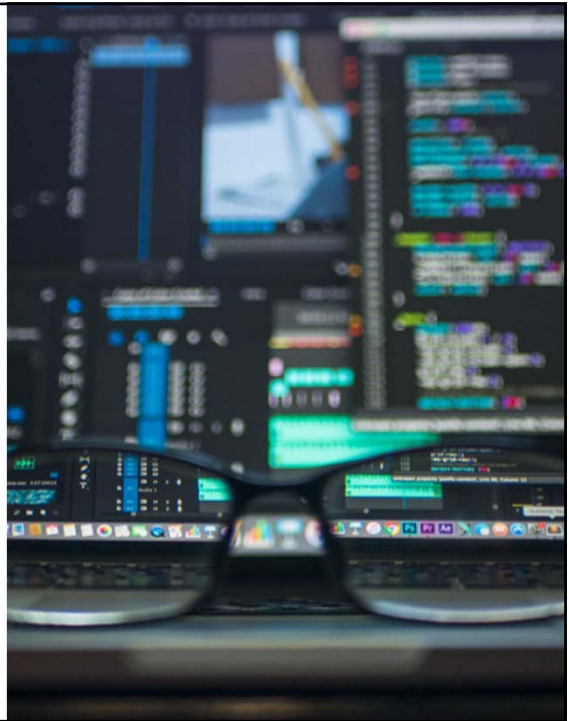
98



ACTIVITY

You have been assigned to assist the incident response team in evaluating post-incident lessons learned and remediation activities to prevent recurrence of the root causes. Your team has completed the response to data leakage that resulted in compromising firewall network administrative access.

When the firewall was sent off site for vendor maintenance, what actions should have been taken?



99



DISCUSSION QUESTION

The **FIRST** step in data classification is to:

- A. establish ownership.
- B. perform a criticality analysis.
- C. define access rules.
- D. create a data dictionary.



100

DISCUSSION QUESTION

From a control perspective, the **PRIMARY** objective of classifying information assets is to:

- A. establish guidelines for the level of access controls that should be assigned.
- B. ensure access controls are assigned to all information assets.
- C. assist management and auditors in risk assessment.
- D. identify which assets need to be insured against losses.



101

DATA ENCRYPTION AND ENCRYPTION-RELATED TECHNIQUES

ISACA

102

ENCRYPTION

Encryption generally is used to:

- Protect data in transit over networks from unauthorized interception and manipulation.
- Protect information stored on computers from unauthorized viewing and manipulation.
- Deter and detect accidental or intentional alterations of data.
- Verify authenticity of a transaction or document.



103

KEY ELEMENTS OF ENCRYPTION SYSTEMS

Encryption algorithm

- A mathematically based function that encrypts/decrypts data

Encryption key

- A piece of information that is used by the encryption algorithm to make the encryption or decryption process unique

Key length

- A predetermined length for the key; the longer the key, the more difficult it is to compromise

ISACA

104

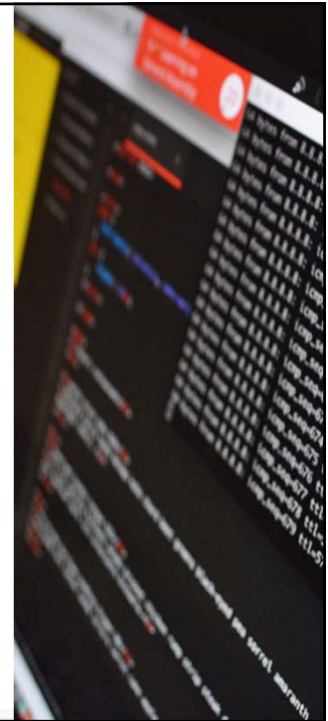
ENCRYPTION SCHEMES

There are two types of encryption schemes:

- Symmetric—a unique key (usually referred to as the “secret key”) is used for both encryption and decryption.
- Asymmetric—the decryption key is different than the one used for encryption.

There are two main advantages of symmetric key systems over asymmetric ones.

- The keys are much shorter and can be easily remembered.
- Symmetric key cryptosystems are generally less complicated and, therefore, use less processing power.



105

PUBLIC KEY CRYPTOGRAPHY

In a public key cryptography system, two keys work together as a pair. One of the keys is kept private, while the other one is publicly disclosed.

The underlying algorithm works even if the private key is used for encryption and the public key for decryption.



106

DIGITAL SIGNATURE SCHEMES

Digital signature schemes ensure:

- Data integrity—Any change to the plaintext message would result in the recipient failing to compute the same document hash.
- Authentication—The recipient can ensure that the document has been sent by the claimed sender because only the claimed sender has the private key.
- Nonrepudiation—The claimed sender cannot later deny generating the document.

The IS auditor should be familiar with how a digital signature functions to protect data.



107

DISCUSSION QUESTION

Which of the following **BEST** determines whether complete encryption and authentication protocols for protecting information while being transmitted exist?

- A. A digital signature with RSA has been implemented.
- B. Work is being done in tunnel mode with the nested services of authentication header (AH) and encapsulating security payload (ESP).
- C. Digital certificates with RSA are being used.
- D. Work is being done in transport mode with the nested services of AH and ESP.



108

PUBLIC KEY INFRASTRUCTURE

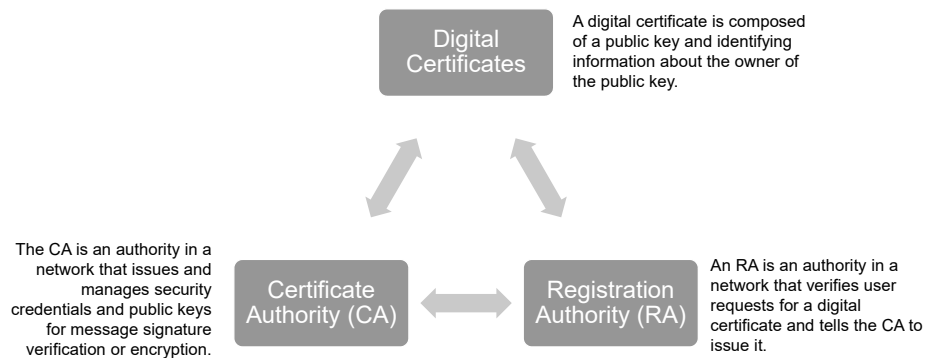
ISACA

109

PUBLIC KEY INFRASTRUCTURE

Public key infrastructure (PKI) allows a trusted third party to issue, maintain and revoke public key certificates.

ELEMENTS OF PKI



ISACA

110

WEB-BASED COMMUNICATIONS TECHNOLOGIES

ISACA

111

VOIP SECURITY

The key to securing VoIP is to use the security mechanisms such as those deployed in data networks (e.g., firewalls, encryption) to emulate the security level currently used by public switched telephone network (PSTN) network users.

OS patches and virus signature updates must be promptly applied to prevent a potential system outage. To enhance the protection of the telephone system and data traffic, the VoIP infrastructure should be segregated using virtual local area networks (VLANs).

Any connections between these two infrastructures should be protected using firewalls that can interpret VoIP protocols.

ISACA

112

EMAIL SECURITY

Issues

- Phishing attacks
- DoS attacks
- Unencrypted emails intercepted
- Viruses
- Email exposure and integrity issues

Control Considerations

- Address the security aspects of the deployment of a mail server through maintenance and administration standards
- Ensure that the mail server application is deployed, configured and managed to meet the security policy and guidelines instituted by management
- Consider the implementation of encryption technologies to protect user authentication and mail data

113

ISACA

113

PEER-TO-PEER COMPUTING

Figure 5.21—Risk of Peer-to-peer Computing		
Threats and Vulnerabilities	Risk	Controls
Introduction of viruses and malware to the organizational network	• Data leakage/theft • "Owned" systems (zombies) • System downtime • Resources required to clean systems	• Ensure that antivirus and anti-malware controls are installed on all systems and updated daily. • Block P2P traffic. • Prevent installation of P2P clients. • Establish or update policies and standards. • Develop and conduct awareness training and campaigns to inform employees of the risk involved with P2P computing.
Copyrighted content held on the enterprises network	• Regulatory sanctions and fines • Adverse legal actions • Licensing issues • Reputational damage	• Block P2P traffic. • Prevent installation of P2P clients. • Establish or update policies and standards. • Develop and conduct awareness training and campaigns to inform employees of the risk involved with P2P computing.
Excessive use of P2P in the workplace	• Network utilization issues • Productivity loss	• Restrict P2P usage. • Establish or update policies and standards. • Develop and conduct awareness training and campaigns to inform employees of the risk involved with P2P computing.
IP address exposure	• IP spoofing • Traffic sniffing • Other IP-based attacks	• Block P2P traffic. • Prevent installation of P2P clients. • Establish or update policies and standards. • Network address translation.

114

ISACA

114

INSTANT MESSAGING

Figure 5.22—Risk of Instant Messaging		
Threats and Vulnerabilities	Risk	Controls
Introduction of viruses and malware to the organizational network (especially through phishing)	• Data leakage/theft • "Owned" systems (zombies) • System downtime • Resources required to clean systems	• Ensure that antivirus and anti-malware controls are installed on all systems and updated daily. • Block IM traffic. • Only allow an enclosed corporate IM solution. • Establish or update policies and standards. • Develop and conduct awareness training and campaigns to inform employees of the risk involved with IM.
Eavesdropping	• Data leakage/theft	• Encrypt IM traffic. • Only allow an enclosed corporate IM solution. • Establish or update policies and standards. • Develop and conduct awareness training and campaigns to inform employees of the risk involved with IM.
Excessive use of IM in the workplace	• Network utilization issues • Productivity loss	• Restrict IM usage. • Establish or update policies and standards. • De^{VOIP Security} conduct awareness training and campaigns to inform employees of the risk involved with IM.

115

ISACA

115

SOCIAL MEDIA

Along with the corporate social media risk there are risks of employee personal use of social media that should be considered.

Figure 5.23—Risk of a Corporate Social Media Presence		
Threats and Vulnerabilities	Risk	Controls
Introduction of viruses and malware to the organizational network	• Data leakage/theft • "Owned" systems (zombies) • System downtime • Resources required to clean systems	• Ensure that antivirus and anti-malware controls are installed on all systems and updated daily. • Use content filtering technology to restrict or limit access to social media sites. • Ensure that appropriate controls are also installed on mobile devices such as smartphones. • Establish or update policies and standards. • Develop and conduct awareness training and campaigns to inform employees of the risk involved with using social media sites.
Exposure to customers and the enterprise through a fraudulent or hijacked corporate presence	• Customer backlash/adverse legal actions • Exposure of customer information • Reputational damage • Targeted phishing attacks on customers or employees	• Engage a brand protection firm that can scan the Internet and search out misuse of the enterprise brand. • Give periodic informational updates to customers to maintain awareness of potential fraud and to establish clear guidelines regarding what information should be posted as part of the enterprise social media presence.
Unclear or undefined content rights to information posted to social media sites	• Enterprise's loss of control/legal rights of information posted to the social media sites	• Ensure that legal and communications teams carefully review user agreements for social media sites that are being considered. • Establish clear policies that dictate to employees and customers what information should be posted as part of the enterprise social media presence. • If feasible and appropriate, ensure that there is a capability to capture and log all communications.
A move to a digital business model may increase customer service expectations.	• Customer dissatisfaction with the responsiveness received in this arena, leading to potential reputational damage for the enterprise and customer retention issues	• Ensure that staffing is adequate to handle the amount of traffic that could be created from a social media presence. • Create notices that provide clear windows for customer response.
Mismanagement of electronic communications that may be impacted by retention regulations or ediscovery	• Regulatory sanctions and fines • Adverse legal actions	• Establish appropriate policies, processes and technologies to ensure that communications via social media that may be impacted by litigation or regulations are tracked and archived appropriately. • Note that, depending on the social media site, maintaining an archive may not be a recommended approach.

Source: ISACA, Social Media: Business Benefits and Security, Governance and Assurance Perspectives, USA, 2010, figure 1

116

CLOUD COMPUTING SERVICE MODELS

Figure 5.25—Cloud Computing Service Models		
Service Model	Definition	To Be Considered
Infrastructure as a Service (IaaS)	Capability to provision processing, storage, networks and other fundamental computing resources, offering the customer the ability to deploy and run arbitrary software, which can include operating systems and applications. IaaS puts these IT operations into the hands of a third party.	Options to minimize the impact if the cloud provider has a service interruption Peer-to-Peer Computing
Platform as a Service (PaaS)	Capability to deploy onto the cloud infrastructure customer-created or acquired applications created using programming languages and tools supported by the provider	• Availability • Confidentiality • Privacy and legal liability in the event of a security breach (as databases housing sensitive information will now be hosted offsite) • Data ownership • Concerns around ediscovery
Software as a Service (SaaS)	Capability to use the provider's applications running on cloud infrastructure. The applications are accessible from various client devices through a thin client interface such as a web browser (e.g., web-based email).	• Who owns the applications? • Where do the applications reside?
ISACA, <i>Cloud Computing: Business Benefits With Security, Governance and Assurance Perspectives</i> , USA, 2009, figure 1, page 5, www.isaca.org/Knowledge-Center/Research/ResearchDeliverables/Pages/Cloud-Computing-Business-Benefits-With-Security-Governance-and-Assurance-Perspective.aspx		

117

ISACA

117

CLOUD COMPUTING DEPLOYMENT MODELS

Figure 5.26—Cloud Computing Deployment Models		
Deployment Model	Description of Cloud Infrastructure	To Be Considered
Private cloud	• Operated solely for an organization • May be managed by the organization or a third party • May exist on-premise or off-premise	• Cloud services with minimum risk • May not provide the scalability and agility of public cloud services
Community cloud	• Shared by several organizations • Supports a specific community that has shared mission or interest. • May be managed by the organizations or a third party • May reside on-premise or off-premise	• Same as private cloud, plus: • Data may be stored with the data of competitors.
Public cloud	• Made available to the general public or a large industry group • Owned by an organization selling cloud services	• Same as community cloud, plus: • Data may be stored in unknown locations and may not be easily retrievable.
Hybrid cloud	A composition of two or more clouds (private, community or public) that remain unique entities but are bound together by standardized or proprietary technology that enables data and application portability (e.g., cloud bursting for load balancing between clouds)	• Aggregate risk of merging different deployment models • Classification and labeling of data will be beneficial to the security manager to ensure that data are assigned to the correct cloud type.
ISACA, <i>Cloud Computing: Business Benefits With Security, Governance and Assurance Perspectives</i> , USA, 2009, figure 2, page 5, www.isaca.org/Knowledge-Center/Research/ResearchDeliverables/Pages/Cloud-Computing-Business-Benefits-With-Security-Governance-and-Assurance-Perspective.aspx		

118

ISACA

118

CLOUD COMPUTING ESSENTIAL CHARACTERISTICS

Figure 5.27—Cloud Computing Essential Characteristics

Characteristic	Definition
On-demand self-service	The cloud provider should have the ability to automatically provision computing capabilities, such as server and network storage, as needed without requiring human interaction with each service's provider.
Broad network access	According to NIST, the cloud network should be accessible anywhere, by almost any device (e.g., smart phone, laptop, mobile devices).
Resource pooling	The provider's computing resources are pooled to serve multiple customers using a multitenant model, with different physical and virtual resources dynamically assigned and reassigned according to demand. There is a sense of location independence. The customer generally has no control or knowledge over the exact location of the provided resources. However, he/she may be able to specify location at a higher level of abstraction (e.g., country, region or data center). Examples of resources include storage, processing, memory, network bandwidth and virtual machines.
Rapid elasticity	Capabilities can be rapidly and elastically provisioned, in many cases automatically, to scale out quickly and rapidly released to scale in quickly. To the customer, the capabilities available for provisioning often appear to be unlimited and can be purchased in any quantity at any time.
Measured service	Cloud systems automatically control and optimize resource use by leveraging a metering capability (e.g., storage, processing, bandwidth and active user accounts). Resource usage can be monitored, controlled and reported, providing transparency for both the provider and customer of the utilized service.

ISACA, *Cloud Computing: Business Benefits With Security, Governance and Assurance Perspectives*, USA, 2009, figure 3, page 6, www.isaca.org/Knowledge-Center/Research/ResearchDeliverables/Pages/Cloud-Computing-Business-Benefits-With-Security-Governance-and-Assurance-Perspective.aspx

119

ISACA

119

CLOUD SECURITY OBJECTIVES

Ensure the continued availability of their information systems and data.

Ensure the integrity and preserve the confidentiality information and sensitive data while stored and in transit.

Ensure conformity to applicable laws, regulations and standards.

Ensure adherence to trust and obligation requirements in relation to any information relating to an identified or identifiable individual (i.e., data subject) in accordance with its privacy policy or applicable privacy laws and regulations.

120

ISACA

120

IS AUDITOR AND CLOUD COMPUTING

Some considerations for the IS auditor regarding cloud computing include:

- Data ownership, data custody and security administration related to cloud deployment models: The CSA provides a questionnaire that organizations can use to ascertain a service providers compliance to the Controls Matrix.
- Legal requirements and unique risks in the cloud environment: Regulations such as GDPR can present unique challenges for data stored in the cloud.
- Potential limitations to the right-to-audit in a cloud environment: An auditor may not be able to physically investigate a vendor's facilities.

121

ISACA

121

VIRTUALIZED ENVIRONMENTS

122

ISACA

122

VIRTUALIZED ENVIRONMENTS

Bare metal/native virtualization occurs when the hypervisor runs directly on the underlying hardware, without a host OS.

Hosted virtualization occurs when the hypervisor runs on top of the host OS (Windows, Linux or MacOS). The hosted virtualization architectures usually have an additional layer of software (the virtualization application) running in the guest OS that provides utilities to control the virtualization while in the guest OS, such as the ability to share files with the host OS.

Containerization: Containers include the application and all of its dependencies but share the kernel with other containers. They run as an isolated process in user space on the host operating system.

123

ISACA

123

VIRTUALIZATION RISK

The following types of high-level risk are representative of the majority of virtualized systems in use:

Rootkits

- Improper configuration
- Guest tools
- Snapshot/images

124

Virtualization products rarely have hypervisor access controls: Therefore, anyone who can launch an application on the host OS can run the hypervisor.

The only access control is whether someone can log into the host OS.

ISACA

124

VIRTUALIZATION TYPICAL CONTROLS

An IS auditor should understand the following concepts:

- Hypervisors and guest images (OS and networks) are securely configured according to industry standards. Apply hardening to these virtual components as closely as one would to a physical server, switch, router, firewall or other computing device.
- Hypervisor management communications should be protected on a dedicated management network. Management communications carried on untrusted networks should be encrypted, and encryption should encapsulate the management traffic.
- The hypervisor should be patched as the vendor releases the fixes.
- The virtualized infrastructure should be synchronized to a trusted authoritative timeserver.
- Unused physical hardware should be disconnected from the host system.
- All hypervisor services, such as clipboard- or file-sharing between the guest OS and the host OS, should be disabled unless they are needed.
- Host inspection capabilities should be enabled to monitor the security of each guest OS. Hypervisor security services can allow security monitoring even when the guest OS is compromised.
- Host inspection capabilities should be enabled to monitor the security of activity occurring between guest OSs. Of special focus is communications in a non-virtualized environment carried

125

ISACA

125

MOBILE, WIRELESS AND INTERNET-OF-THINGS

126

ISACA

126

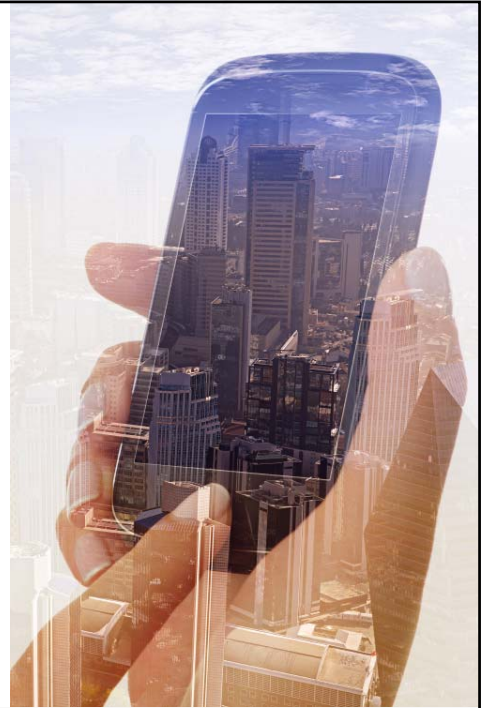
MOBILE COMPUTING

Mobile computing refers to devices that are transported or moved during normal usage, including tablets, smartphones and laptops.

Mobile computing makes it more difficult to implement logical and physical access controls.

Common mobile computing vulnerabilities include the following:

- Information may travel across unsecured wireless networks.
- The enterprise may not be managing the device.
- Unencrypted information may be stored on the device.
- The device may have a lack of authentication requirements.
- The device may allow for the installation of unsigned third-party applications.



127

MOBILE COMPUTING CONTROLS

The following controls will reduce the risk of disclosure of sensitive data stored on mobile devices:

Device registration	Tagging	Physical security	Data storage	Virus detection and control
Encryption	Compliance	Approval	Acceptable use policy	Due care
Awareness training	Network authentication	Secure transmission	Standard applications	Geolocation tracking
	Remote wipe and lock	BYOD agreement	Secure remote support	

ISACA

128

BYOD SECURITY AND CONTROL ISSUES

Protection of sensitive data and intellectual property

Protection of networks to which BYOD devices connect

Responsibility and accountability for the device and information contained on it

Removal of the organization's data from employee-owned devices upon termination of employment or loss of the device

Malware protection

129



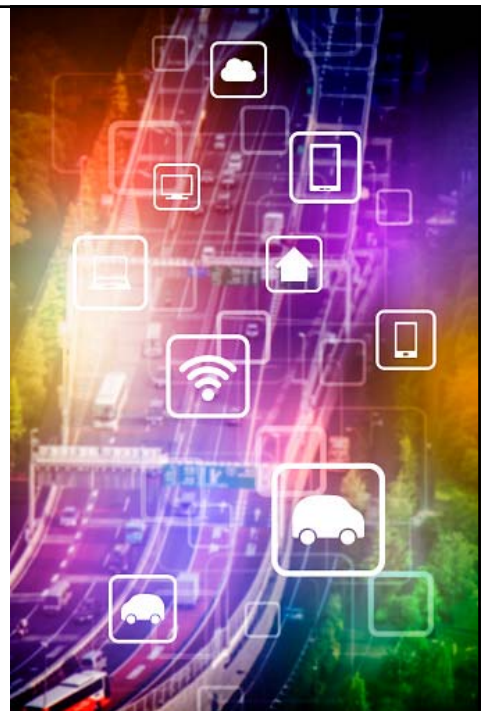
129

BYOD RISKS

Risks related to BYOD are similar to mobile computing risks. Some specific BYOD-related risks are:

- Access controls and control over device security.
- Ability to eliminate sensitive enterprise data upon termination of employment or loss of the device.
- Management issues related to supporting many different types of devices, operating systems and applications.
- Ensuring that employee-owned BYOD devices are properly backed up at all times .

130



130

INTERNET ACCESS ON MOBILE DEVICES RISKS

The interception of sensitive information	Possible health effects of device usage
The loss or theft of devices	OS vulnerabilities
The loss of data contained in the devices	Applications
The misuse of devices	Wireless user authentication
Distractions caused by the devices	File security
	Wired equivalent privacy (WEP) security encryption

131

ISACA

131

WIRELESS SECURITY THREATS AND RISK MITIGATION

Classification of threats:	Mitigation strategies
• Errors and omissions • Fraud and theft committed by authorized or unauthorized users of the system • Employee sabotage • Loss of physical and infrastructure support • Malicious hackers • Industrial espionage • Malicious code • Foreign government espionage • Threats to personal privacy	• Authenticity • Nonrepudiation • Accountability • Network availability

132

ISACA

132

INTERNET OF THINGS RISK

Business risk:

- Health and safety
- Regulatory compliance
- User privacy
- Unexpected costs

Operational risk

- Inappropriate access to functionality
- Shadow usage
- Performance

Technical risk:

- Device vulnerabilities
- Device updates
- Device management

133

ISACA

133

ISACA®

SECURITY EVENT MANAGEMENT

134

134

SECURITY AWARENESS TRAINING AND PROGRAMS

ISACA

135

SECURITY AWARENESS TRAINING

An active security awareness program can greatly reduce risk by addressing the behavioral element of security through education and consistent application of awareness techniques.

All employees of an organization and third-party users must receive appropriate training and regular updates on the importance of security policies, standards and procedures in the organization.

In addition, all personnel must be trained in their specific responsibilities related to information security.

ISACA

136

DISCUSSION QUESTION

Which of the following is the **BEST** way for an IS auditor to determine the effectiveness of a security awareness and training program?

- A. Review the security training program.
- B. Ask the security administrator.
- C. Interview a sample of employees.
- D. Review the security reminders to employees.



137

INFORMATION SYSTEM ATTACK METHODS AND TECHNIQUES

ISACA

138

FRAUD RISK FACTORS



139

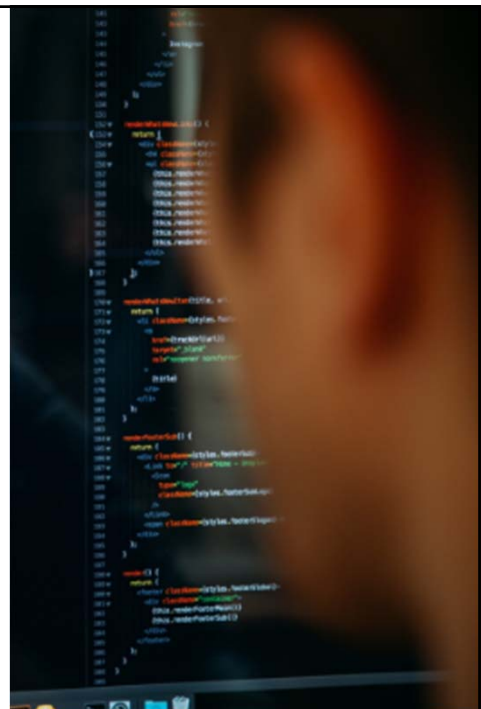
ISACA

139

COMPUTER CRIMES

- Financial loss
- Legal repercussions
- Loss of credibility or competitive edge
- Blackmail/industrial espionage/organized crime
- Disclosure of confidential, sensitive or embarrassing information
- Sabotage

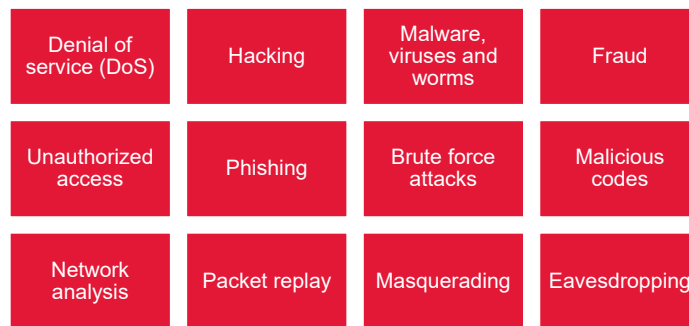
140



140

COMPUTER CRIMES

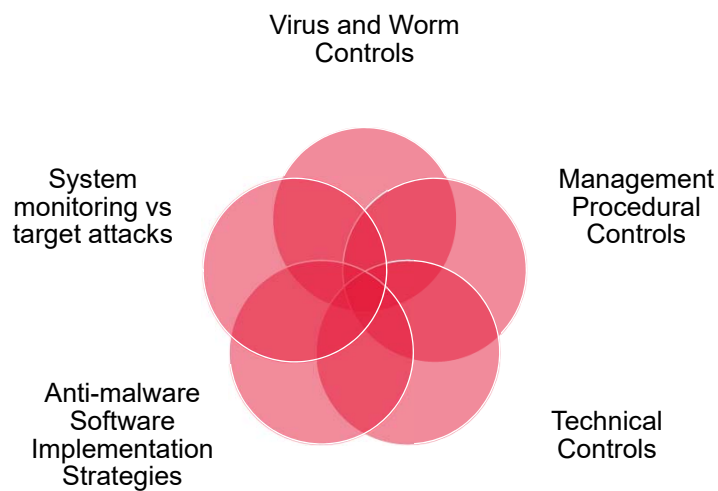
It is important that the IS auditor knows and understands the differences between computer crime and computer abuse to support risk analysis methodologies and related control practices. Examples of computer crimes include:



ISACA

141

MALWARE CONTROLS



142

ISACA

142

SECURITY TESTING TOOLS AND TECHNIQUES

ISACA

143

SECURITY TESTING TECHNIQUES

Terminal cards and keys

- The IS auditor can use sample cards and keys to attempt to gain access beyond what is authorized.
- The IS auditor should follow up on any unsuccessful attempted violations.

Terminal identification

- The IS auditor can inventory terminals to look for incorrectly logged, missing or additional terminals.

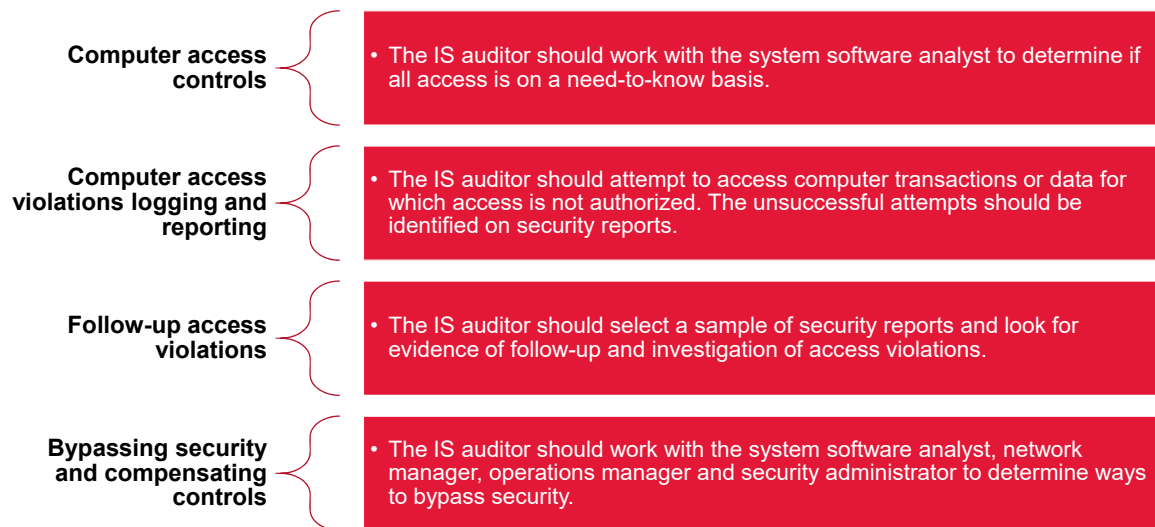
Logon IDs and passwords

- To test confidentiality, the IS auditor can attempt to guess passwords, find passwords by searching the office or get a user to divulge a password.
- To test encryption, the IS auditor should attempt to view the internal password table.
- To test authorization, the IS auditor should review a sample of authorization documents to determine if proper authority was provided.

ISACA

144

SECURITY TESTING TECHNIQUES (CONT'D)



ISACA

145

PENETRATION TESTING

During penetration testing, an auditor attempts to circumvent the security features of a system and exploits the vulnerabilities to gain access that would otherwise be unauthorized.



ISACA

146

TYPES OF PENETRATION TESTS

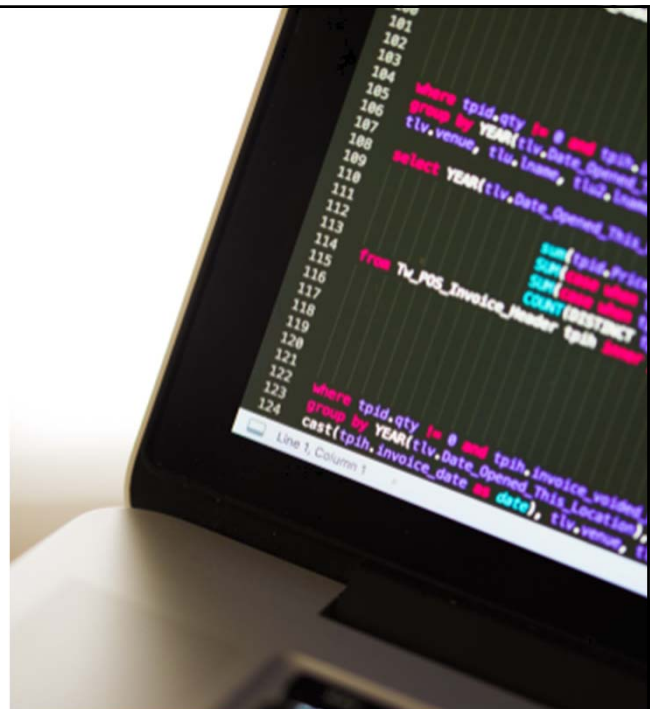
External testing	Refers to attacks and control circumvention attempts on the target's network perimeter from outside the target's system
Internal testing	Refers to attacks and control circumvention attempts on the target from within the perimeter
Blind testing	Refers to the condition of testing when the penetration tester is provided with limited or no knowledge of the target's information systems
Double blind testing	Refers to an extension of blind testing, because the administrator and security staff at the target are also not aware of the test
Targeted testing	Refers to attacks and control circumvention attempts on the target, while both the target's IT team and penetration testers are aware of the testing activities

ISACA

147

THREAT INTELLIGENCE

Threat intelligence is organized, analyzed and refined information about potential or current attacks that threaten an organization provided by the service providers and some CERTs.



148

148

DISCUSSION QUESTION

An IS auditor is evaluating network performance for an organization that is considering increasing its Internet bandwidth due to a performance degradation during business hours. Which of the following is **MOST** likely the cause of the performance degradation?

- A. Malware on servers
- B. Firewall misconfiguration
- C. Increased spam received by the email server
- D. Unauthorized network activities



149

SECURITY MONITORING TOOLS AND TECHNIQUES

150

ISACA

150

INTRUSION DETECTION SYSTEMS

Categories

- Network-based IDSs
- Host-based IDSs

Types

- Signature-based
- Statistical-based
- Neural networks

Policy

- Terminate the access
- Trace the access

151

A combination of signature- and statistical-based models provides better protection.

ISACA

151

INTRUSION PREVENTION SYSTEMS

Honeypots

- High-interaction
- Low-interaction

Honeynet – a set of linked honeypots

A full review of all network system vulnerabilities should occur to determine whether the threats to confidentiality, integrity and availability have been identified.

Review:

- Security policies and procedures
- Access controls
- Network configuration (firewalls and segmentation)

152

IPSs prevent the intended victim hosts from being affected by the attacks.

ISACA

152

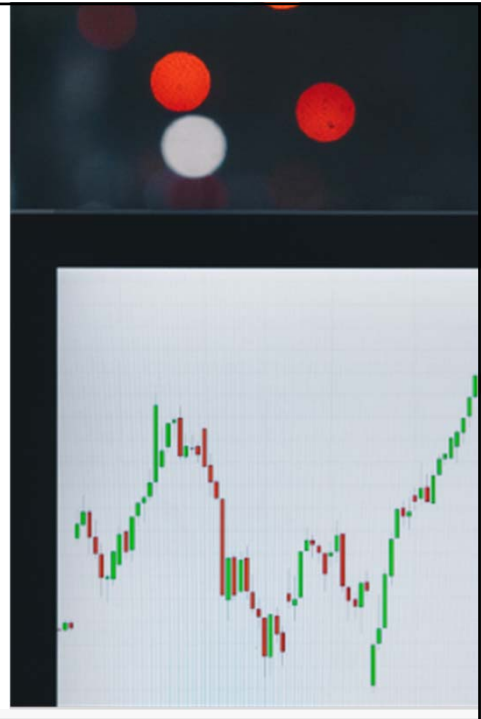
SECURITY INFORMATION AND EVENT MANAGEMENT

SEM systems automatically aggregate and correlate security event log data across multiple security devices.

Security information and event management (SIEM) systems take the SEM capabilities and combine them with the historical analysis and reporting features of security information management (SIM) systems.

A SOC consists of an organized team created to improve the security posture of an organization and to respond to cybersecurity incidents.

153

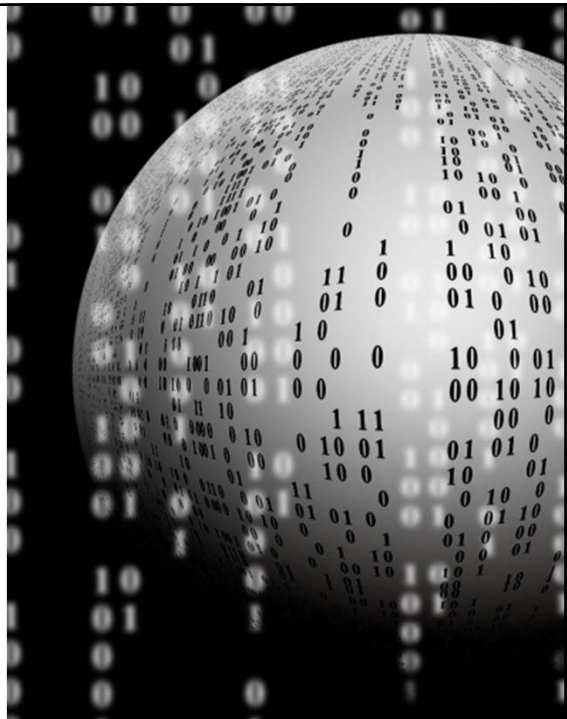


153

DISCUSSION QUESTION

Neural networks are effective in detecting fraud because they can:

- A. discover new trends because they are inherently linear.
- B. solve problems where large and general sets of training data are not obtainable.
- C. attack problems that require consideration of a large number of input variables.
- D. make assumptions about the shape of any curve relating variables to the output.



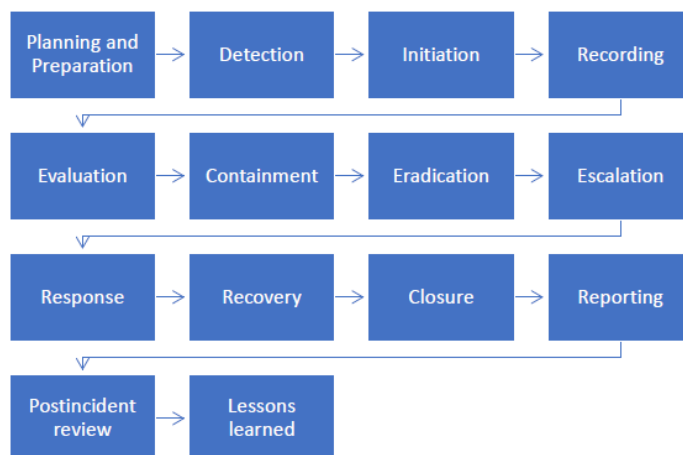
154

INCIDENT RESPONSE MANAGEMENT

ISACA

155

INCIDENT RESPONSE MANAGEMENT PLAN



ISACA

156

EVIDENCE COLLECTION AND FORENSICS

ISACA

157

COMPUTER FORENSICS

The IS auditor should give consideration to key elements of computer forensics during audit planning, including the following:

- Data protection
- Data acquisition
- Imaging
- Extraction
- Interrogation
- Ingestion/normalization
- Reporting



158

PROTECTION OF EVIDENCE AND CHAIN OF CUSTODY

The evidence of a computer crime exists in the form of log files, file time stamps, contents of memory, etc.

- Make a copy or more image of the attacked system.
- Memory content should also be dumped to a file before rebooting the system.
- Preserve the chain of custody.

159

```
self.file = None
self.fingerprints = set()
self.logdupes = True
self.debug = debug
self.logger = logging.getLogger(__name__)
if path:
    self.file = open(os.path.join(path, 'fingerprints.log'), 'a')
    self.file.seek(0)
    self.fingerprints.update(fingerprints)

@classmethod
def from_settings(cls, settings):
    debug = settings.getboolean('debug')
    return cls(job_dir(settings), debug)

def request_seen(self, request):
    fp = self.request_fingerprint(request)
    if fp in self.fingerprints:
        return True
    self.fingerprints.add(fp)
    if self.file:
        self.file.write(fp + '\n')

def request_fingerprint(self, request):
    return request_fingerprint(request)
```

159

DISCUSSION QUESTION

The CSIRT of an organization disseminates detailed descriptions of recent threats. An IS auditor's **GREATEST** concern should be that the users may:

- A. use this information to launch attacks.
- B. forward the security alert.
- C. implement individual solutions.
- D. fail to understand the threat.

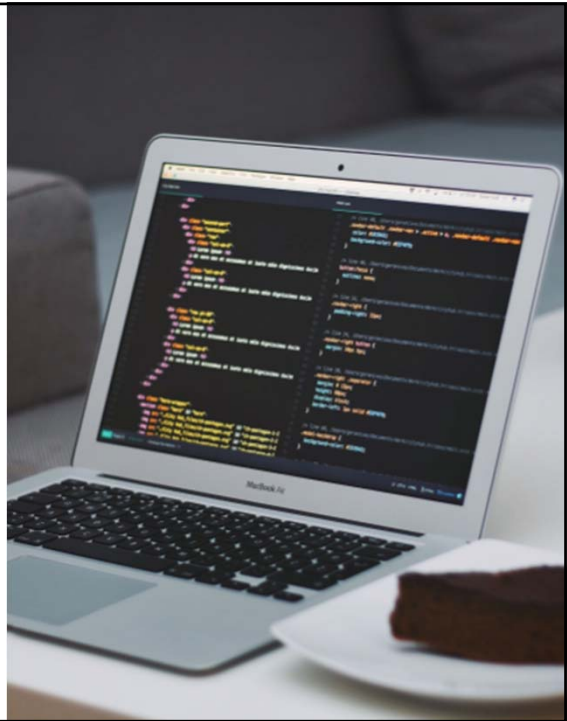


160

DISCUSSION QUESTION

A hard disk containing confidential data was damaged beyond repair. What should be done to the hard disk to prevent access to the data residing on it?

- A. Rewrite the hard disk with random 0s and 1s.
- B. Low-level format the hard disk.
- C. Demagnetize the hard disk.
- D. Physically destroy the hard disk.



161

PRACTICE QUESTIONS

ISACA

162

PRACTICE QUESTION

In an organization where an IT security baseline has been defined an IS auditor should **FIRST** ensure:

- A. implementation.
- B. compliance.
- C. documentation.
- D. sufficiency.

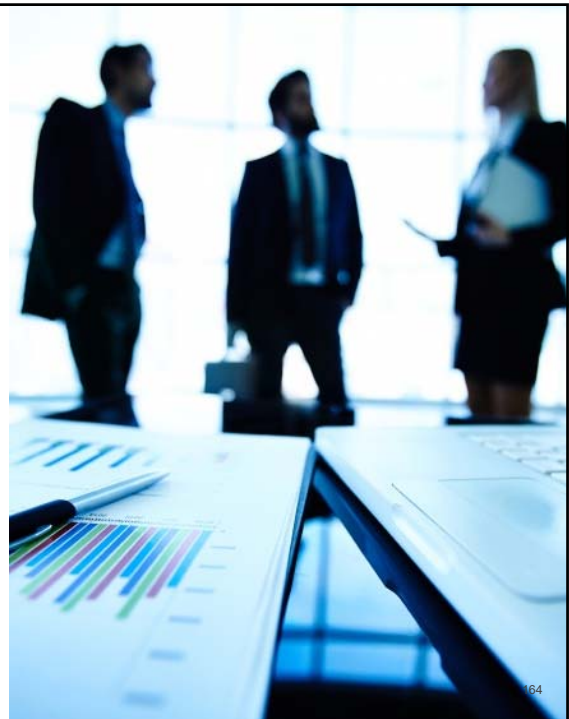


163

PRACTICE QUESTION

Which of the following is the **MOST** secure way to remove data from obsolete magnetic tapes during a disposal?

- A. Overwriting the tapes
- B. Initializing the tape labels
- C. Degaussing the tapes
- D. Erasing the tapes

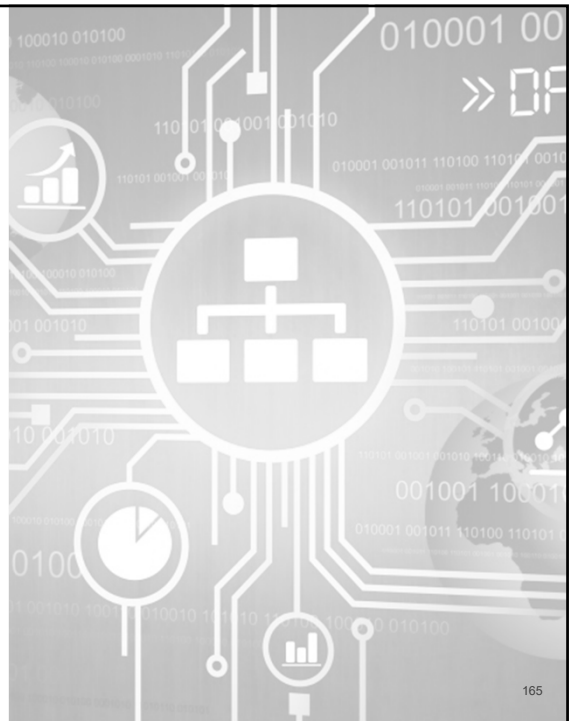


164

PRACTICE QUESTION

An organization allows for the use of universal serial bus drives to transfer operational data between offices. Which of the following is the **GREATEST** risk associated with the use of these devices?

- A. Files are not backed up
- B. Theft of the devices
- C. Use of the devices for personal purposes
- D. Introduction of malware into the network

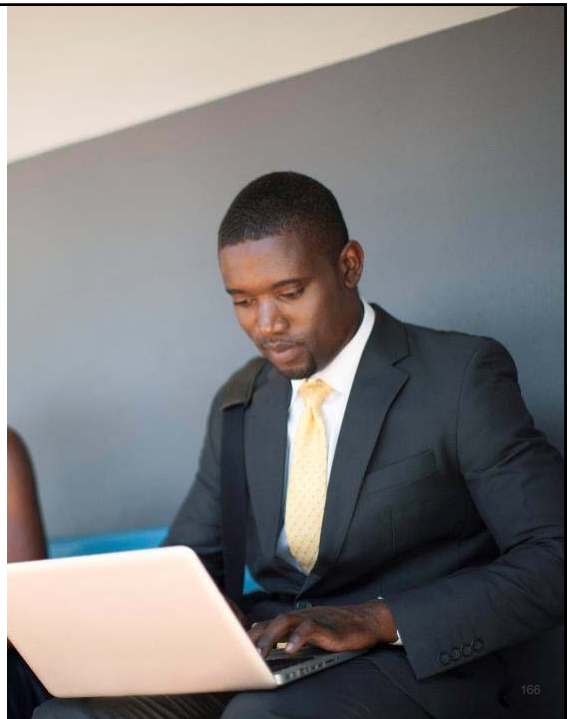


165

PRACTICE QUESTION

With the help of a security officer, granting access to data is the responsibility of:

- A. data owners.
- B. programmers.
- C. system analysts.
- D. librarians.



166

PRACTICE QUESTION

Which of the following types of penetration tests simulates a real attack and is used to test incident handling and response capability of the target?

- A. Blind testing
- B. Targeted testing
- C. Double-blind testing
- D. External testing

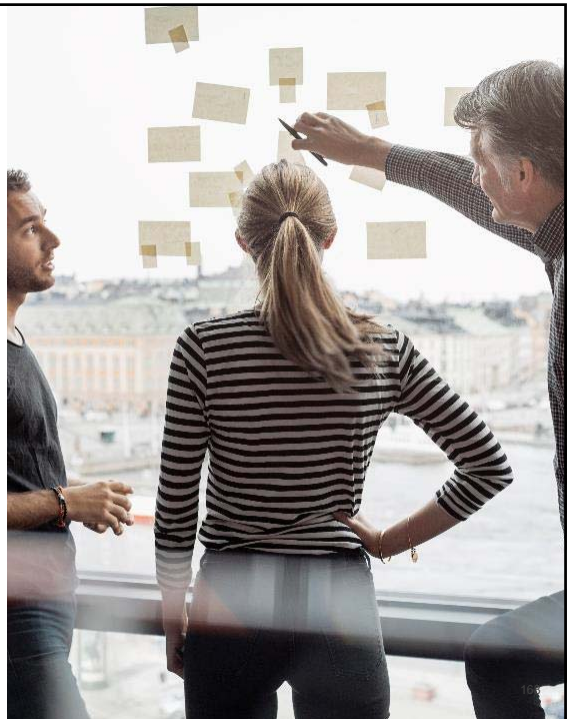


167

PRACTICE QUESTION

Which of the following is the responsibility of information asset owners?

- A. Implementation of information security within applications
- B. Assignment of criticality levels to data
- C. Implementation of access rules to data and programs
- D. Provision of physical and logical security for data

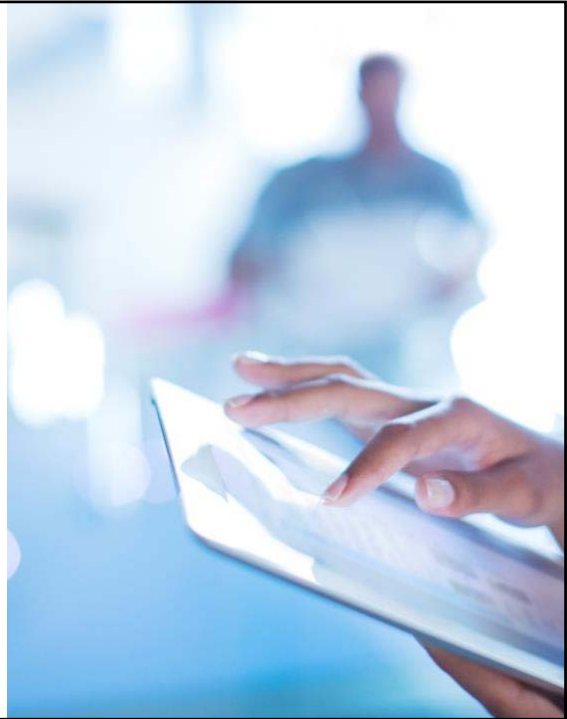


168

PRACTICE QUESTION

Which of the following cryptography options would increase overhead/cost?

- A. The encryption is symmetric rather than asymmetric.
- B. A long asymmetric encryption key is used.
- C. The hash is encrypted rather than the message.
- D. A secret key is used.

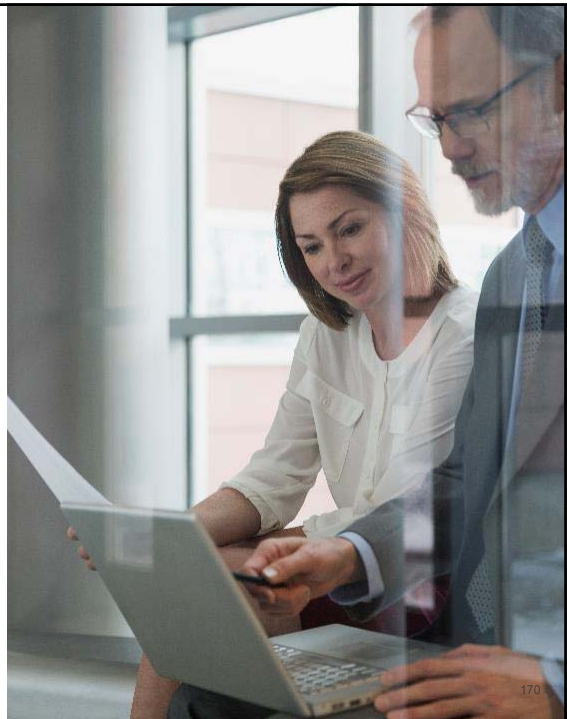


169

PRACTICE QUESTION

Which of the following is the **MOST** significant function of a corporate public key infrastructure and certificate authority employing X.509 digital certificates?

- A. It provides the public/private key set for the encryption and signature services used by email and file space.
- B. It binds a digital certificate and its public key to an individual subscriber's identity.
- C. It provides the authoritative source for employee identity and personal details.
- D. It provides the authoritative authentication source for object access.



170

PRACTICE QUESTION

An internal audit function is reviewing an internally developed common gateway interface script for a web application. The IS auditor discovers that the script was not reviewed and tested by the quality control function. Which of the following types of risk is of **GREATEST** concern?

- A. System unavailability
- B. Exposure to malware
- C. Unauthorized access
- D. System integrity



171

PRACTICE QUESTION

Which of the following is the **MOST** important security consideration to an organization that wants to move a business application to external cloud-service (PaaS) provided by a vendor?

- A. Classification and categories of data process by the application.
- B. Cost of hosting the application internally versus externally.
- C. A reputation of a vendor on the market and feedbacks from clients.
- D. Drop of application performance due to use of shared services.

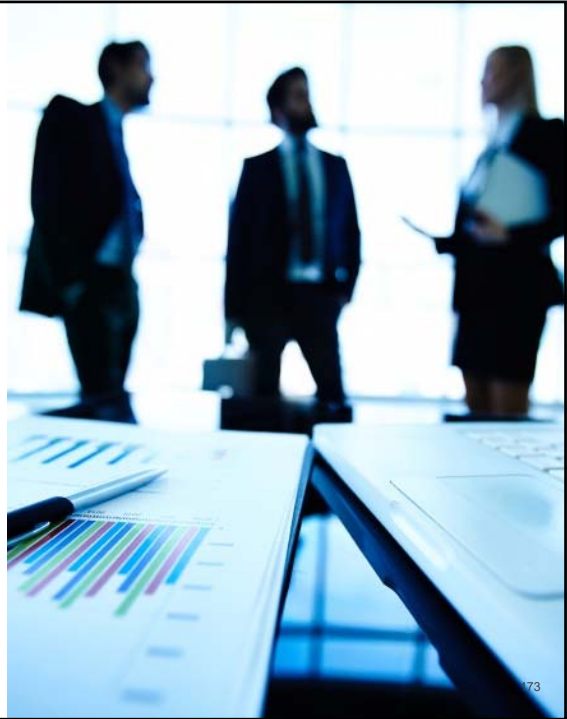


172

PRACTICE QUESTION

An organization is proposing to establish a wireless local area network (WLAN). Management asks the IS auditor to recommend security controls for the WLAN. Which of the following would be the **MOST** appropriate recommendation?

- A. Physically secure wireless access points to prevent tampering.
- B. Use service set identifiers that clearly identify the organization.
- C. Encrypt traffic using the Wired Equivalent Privacy mechanism.
- D. Implement the Simple Network Management Protocol to allow active monitoring.



173

PRACTICE QUESTION

A data center has a badge-entry system. Which of the following is **MOST** important to protect the computing assets in the center?

- A. Badge readers are installed in locations where tampering would be noticed.
- B. The computer that controls the badge system is backed up frequently.
- C. A process for promptly deactivating lost or stolen badges is followed.
- D. All badge entry attempts are logged, whether or not they succeed.

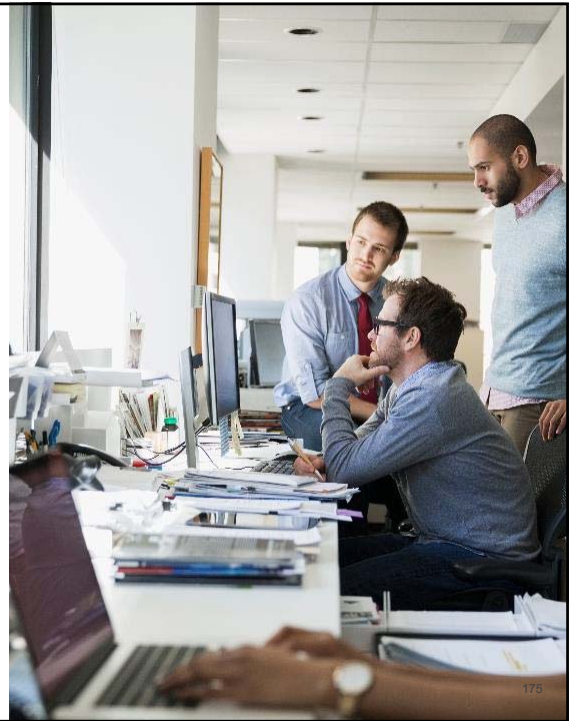


174

PRACTICE QUESTION

What is the **BEST** approach to mitigate the risk of a phishing attack?

- A. Intrusion detection
- B. Security assessment
- C. Strong authentication
- D. User education



175

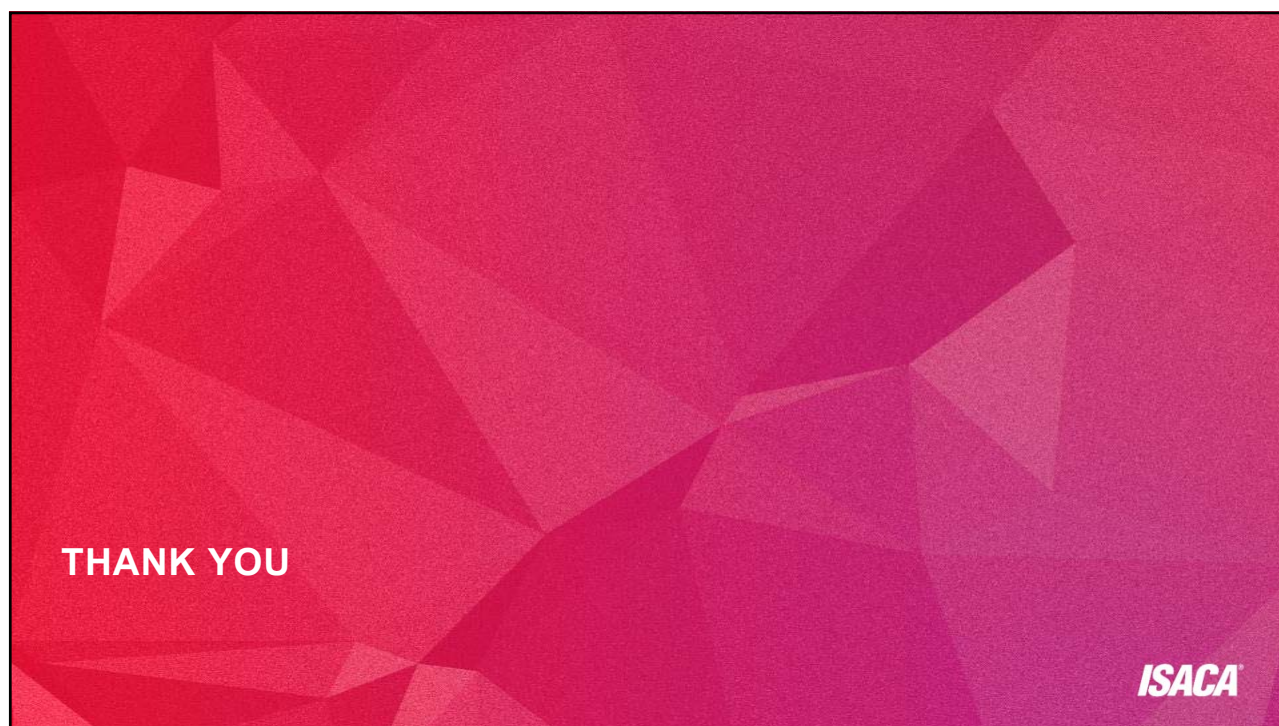
DOMAIN 5 REVIEW

You should now be able to:

- Conduct audit in accordance with IS audit standards and a risk-based IS audit strategy.
- Evaluate problem and incident management policies and practices.
- Evaluate the organization's information security and privacy policies and practices.
- Evaluate physical and environmental controls to determine whether information assets are adequately safeguarded.
- Evaluate logical security controls to verify the confidentiality, integrity, and availability of information.
- Evaluate data classification practices for alignment with the organization's policies and applicable external requirements.
- Evaluate policies and practices related to asset lifecycle management.
- Evaluate the information security program to determine its effectiveness and alignment with the organization's strategies and objectives.
- Perform technical security testing to identify potential threats and vulnerabilities.
- Evaluate potential opportunities and threats associated with emerging technologies, regulations, and industry practices.

ISACA

176



177